

Sistemi e Reti - Appunti per la maturita

Nota di lavoro

Questa e una prima struttura del documento, costruita sul programma annuale fornito. Il modello segue l'impostazione del documento di Italiano: schede ordinate per modulo, spiegazioni sintetiche, parole chiave e sezioni da integrare con le presentazioni.

Quando arriveranno le slide o gli appunti dei singoli moduli, ogni sezione potra essere completata con definizioni, esempi, schemi e collegamenti per l'esame orale.

Scheda 1

MODULO I - Richiami allo strato di trasporto

UNITA 1 - Il livello di trasporto e il protocollo UDP

Obiettivo del modulo

Ripassare il ruolo dello strato di trasporto nel modello TCP/IP, con particolare attenzione alla differenza tra comunicazione affidabile e non affidabile, tra protocolli connectionless e connection oriented, e al funzionamento dei protocolli UDP e TCP.

Argomenti da sviluppare

- Trasferimento affidabile dei segmenti.
- Trasmissione connectionless e connection oriented.
- Three-way handshaking.
- Protocollo UDP.
- Protocollo TCP.

Schema sintetico iniziale

Lo strato di trasporto mette in comunicazione processi applicativi presenti su host diversi. Lavora sopra lo strato di rete e permette alle applicazioni di scambiarsi dati usando le porte, che identificano i servizi in esecuzione su una macchina.

Il livello di rete realizza una comunicazione logica tra host, cioè tra macchine. Il livello di trasporto realizza invece una comunicazione logica tra processi, cioè tra programmi in esecuzione sugli host. Per questo motivo non basta conoscere l'indirizzo IP del computer: serve anche sapere a quale applicazione devono essere consegnati i dati.

UDP e TCP rappresentano due modi diversi di gestire la comunicazione:

- UDP e connectionless: non stabilisce una connessione prima dell'invio, non garantisce consegna, ordine o ritrasmissione dei segmenti.
- TCP e connection oriented: stabilisce una connessione logica, controlla il flusso, gestisce gli errori e garantisce una consegna affidabile.

Il three-way handshaking è la procedura con cui TCP apre una connessione:

1. il client invia un segmento SYN;
2. il server risponde con SYN-ACK;
3. il client conferma con ACK.

Servizio e protocollo

Nel modello a livelli bisogna distinguere servizio e protocollo.

Un servizio è l'insieme delle operazioni che un livello mette a disposizione del livello superiore. Un protocollo è invece l'insieme delle regole che stabiliscono formato e significato dei messaggi scambiati tra

entità dello stesso livello su macchine diverse.

Le entità di livello usano i protocolli per realizzare i servizi. Per esempio, il livello di trasporto offre alle applicazioni la possibilità di inviare dati; per farlo usa protocolli come TCP e UDP.

SAP, porte e socket

Le SAP, Service Access Point, sono punti logici attraverso cui un livello superiore accede ai servizi del livello inferiore. Nel livello di trasporto le SAP corrispondono alle porte.

Le porte sono numeri a 16 bit, quindi vanno da 0 a 65535. Servono per distinguere le varie applicazioni attive su uno stesso host. Senza le porte, un computer potrebbe ricevere un pacchetto IP ma non saprebbe a quale programma consegnarlo.

Le porte si dividono in tre gruppi:

- Well Known Ports, da 0 a 1023: porte riservate ai servizi più comuni, come HTTP, FTP, SMTP, DNS e POP3.
- Registered Ports, da 1024 a 49151: porte registrate o usate liberamente da molte applicazioni.
- Dynamic Ports, da 49152 a 65535: porte assegnate dinamicamente ai processi client.

Alcune porte importanti:

Porta	Servizio	Protocollo
20	FTP dati	TCP
21	FTP controllo	TCP
23	Telnet	TCP
25	SMTP	TCP
53	DNS	TCP/UDP
80	HTTP	TCP
110	POP3	TCP

La combinazione tra indirizzo IP e numero di porta prende il nome di socket. Un socket identifica un punto di accesso alla comunicazione:

- socket del mittente: indirizzo IP sorgente + porta sorgente;
- socket del destinatario: indirizzo IP destinazione + porta destinazione.

Una comunicazione tra due processi può essere identificata dalle due coppie IP:porta, una del mittente e una del destinatario. Per esempio, un client può usare la porta locale 5678 per collegarsi al server web 90.35.101.10:80.

Multiplexing e demultiplexing

Una delle funzioni principali del livello di trasporto è la moltiplicazione/demoltiplicazione.

Il multiplexing avviene sul mittente: il livello di trasporto raccoglie dati provenienti da applicazioni diverse, li inserisce in segmenti e aggiunge le intestazioni necessarie, tra cui le porte.

Il demultiplexing avviene sul destinatario: il livello di trasporto riceve i segmenti, legge i numeri di porta e consegna i dati al processo corretto.

Esempio: un utente può navigare sul web e scaricare la posta nello stesso momento. I dati arrivano allo stesso indirizzo IP, ma vengono consegnati ad applicazioni diverse grazie ai numeri di porta.

Può anche accadere che due client diversi usino la stessa porta sorgente per collegarsi allo stesso server. Non è un problema, perché il server distingue le connessioni considerando anche gli indirizzi IP sorgenti.

Servizi affidabili e inaffidabili

Un servizio affidabile assicura che tutti i dati inviati arrivino al destinatario. Per ottenere questa garanzia usa meccanismi come ACK, ritrasmissioni, controllo dell'ordine e controllo degli errori. Questi meccanismi aumentano però l'overhead, cioè il lavoro aggiuntivo e i dati di controllo necessari.

Un servizio inaffidabile non garantisce che i dati arrivino, né che arrivino nello stesso ordine in cui sono stati inviati. Questo può sembrare uno svantaggio, ma in alcuni casi è preferibile perché riduce i ritardi e rende la comunicazione più veloce.

Servizi connection oriented e connectionless

I servizi connection oriented seguono il modello della telefonata:

1. si stabilisce una connessione;
2. si scambiano dati;
3. si chiude la connessione.

TCP appartiene a questa categoria. È connesso e affidabile: crea una connessione logica, controlla la consegna dei dati e ricompone il flusso informativo nell'ordine corretto.

I servizi connectionless seguono il modello della posta ordinaria:

- ogni pacchetto viaggia indipendentemente dagli altri;
- pacchetti con stesso mittente e destinatario possono seguire percorsi diversi;
- possono arrivare in ordine diverso;
- alcuni pacchetti possono anche non arrivare.

UDP appartiene a questa categoria. Non stabilisce una connessione e non garantisce la consegna, ma è semplice e veloce.

Primitive del livello di trasporto

Per accedere ai servizi di un livello si usano funzioni di base chiamate primitive. Ogni primitiva può essere vista come una richiesta o una segnalazione tra chi usa il servizio e chi lo fornisce.

I quattro metodi fondamentali sono:

- request: il service user richiede un servizio;
- indication: il service provider segnala che è arrivata una richiesta;
- response: il service user risponde alla richiesta;
- confirm: il service provider conferma l'esito della richiesta.

In un servizio connection oriented si possono avere primitive come:

1. `connect.request()` ;

```
2. connect.indication();
3. connect.response();
4. connect.confirm();
5. data.request();
6. data.indication();
7. disconnect.request();
8. disconnect.indication();
```

Client, server e buffering

Nell'architettura client-server, il server offre un servizio e resta in ascolto su una porta, mentre il client richiede quel servizio.

Quando un processo viene associato a una porta, il sistema operativo può collegarlo a due code: una di ingresso e una di uscita. Questa funzione prende il nome di buffering e serve a gestire temporaneamente i dati in arrivo e in partenza.

Servizi offerti dal livello di trasporto

Il livello di trasporto può offrire diversi servizi:

- gestione della connessione: apertura e chiusura della connessione quando necessario;
- consegna in ordine corretto: riordino dei pacchetti prima di passarli all'applicazione;
- controllo degli errori: verifica dei dati ricevuti;
- trasferimento affidabile: ritrasmissione dei pacchetti persi;
- controllo di flusso: evita che un host veloce saturi un host più lento;
- controllo di congestione: adatta la velocità di trasmissione allo stato della rete;
- multiplexing e demultiplexing: separazione dei flussi tramite le porte.

Non tutti i protocolli offrono tutti questi servizi. TCP ne offre molti; UDP offre solo un insieme minimo di funzioni.

Qualità del servizio, QoS

La qualità del servizio, o QoS, indica il livello di prestazioni richiesto da una comunicazione. Può essere descritta da parametri come:

- ritardo massimo;
- velocità di consegna;
- tasso di errore;
- probabilità di fallimento della connessione.

Le esigenze cambiano in base all'applicazione. Per una e-mail un ritardo anche elevato può essere accettabile; per streaming audio/video o videoconferenze il ritardo deve essere molto basso.

Il protocollo UDP

UDP, User Datagram Protocol, fornisce un metodo per spedire dati senza stabilire prima una connessione con il destinatario. E quindi un protocollo connectionless e inaffidabile.

Le sue caratteristiche principali sono:

- e veloce, perché ha un header ridotto e non gestisce connessioni;
- supporta trasmissioni broadcast e multicast;
- non garantisce consegna, ordine o ritrasmissione;
- usa le porte per multiplexing e demultiplexing;
- rileva alcuni errori tramite checksum.

UDP viene usato quando la velocità è più importante dell'affidabilità assoluta, per esempio in streaming audio/video, comunicazioni real-time, DNS e altri servizi in cui una ritrasmissione tardiva sarebbe poco utile.

Funzionamento di UDP

Il mittente conosce in anticipo l'indirizzo IP e la porta del destinatario. Crea un segmento UDP, lo incapsula in un datagramma IP e lo invia.

Quando il destinatario riceve il datagramma, il livello IP estrae il segmento UDP e lo passa al livello di trasporto. UDP legge la porta di destinazione:

- se la porta è in ascolto, i dati vengono consegnati all'applicazione;
- se la porta non è in ascolto, può essere inviato al mittente un messaggio ICMP di tipo `port unreachable`.

UDP non recupera gli errori: se un segmento è danneggiato, in alcune implementazioni viene scartato, in altre può essere consegnato all'applicazione con segnalazione dell'errore.

Struttura del segmento UDP

Il segmento UDP ha un header molto semplice, lungo 8 byte. I campi sono:

Campo	Dimensione	Significato
Source Port	16 bit	Porta del mittente
Destination Port	16 bit	Porta del destinatario
Length	16 bit	Lunghezza totale di header + dati
Checksum	16 bit	Controllo degli errori

Dopo l'header si trovano i dati ricevuti dal livello applicativo.

Gli indirizzi IP non sono presenti nell'header UDP perché sono già contenuti nell'header IP che incapsula il segmento.

Checksum UDP

Il checksum serve per rilevare errori nel segmento. Viene calcolato dal mittente e ricontrollato dal destinatario.

Nel calcolo viene usata anche una pseudo-intestazione che contiene informazioni prese dal livello IP, come gli indirizzi IP sorgente e destinazione. Questo permette di verificare non solo il contenuto UDP, ma anche che il segmento sia arrivato tra gli host corretti.

Il checksum rileva errori, ma UDP non effettua ritrasmissioni automatiche. L'eventuale recupero deve essere gestito dall'applicazione, se necessario.

UNITA 2 - Il trasferimento affidabile e il protocollo TCP

Il trasferimento affidabile e l'insieme dei meccanismi che permettono di consegnare i dati correttamente anche se la rete sottostante può perdere, duplicare o consegnare fuori ordine i pacchetti.

Un servizio di trasferimento è considerato affidabile quando garantisce:

- consegna: tutti i messaggi arrivano a destinazione senza errori; se non è possibile, il mittente deve esserne informato;
- assenza di duplicazione: ogni messaggio viene consegnato una sola volta;
- sequenzialità: i messaggi vengono consegnati nello stesso ordine in cui sono stati trasmessi.

Per realizzare queste garanzie si usano vari meccanismi:

- numerazione dei segmenti trasmessi;
- messaggi di riscontro, cioè ACK;
- timer e temporizzazioni in trasmissione;
- ritrasmissione dei segmenti non confermati;
- finestre di trasmissione e ricezione.

RTT e RTO

Due parametri importanti del trasferimento affidabile sono RTT e RTO.

RTT, Round Trip Time, è il tempo che passa tra l'inizio della trasmissione di un segmento e la ricezione del relativo riscontro. In pratica misura il tempo di andata e ritorno di un dato e del suo ACK.

RTO, Retransmission Time Out, è il tempo massimo che il mittente aspetta prima di considerare perso un segmento. Se entro il RTO non arriva l'ACK, il segmento viene ritrasmesso.

Un RTO troppo basso causa ritrasmissioni inutili; un RTO troppo alto rallenta il recupero degli errori. Per questo TCP lo adatta in base alle condizioni della rete.

Numerazione dei segmenti

TCP numera i dati usando il Sequence Number, indicato anche come SN o Seq. Il Sequence Number non identifica genericamente il segmento, ma indica la posizione nel flusso del primo byte contenuto nel segmento.

Il ricevente controlla il Sequence Number:

- se il numero è quello atteso, i dati possono essere passati al livello superiore;
- se il numero è minore di quello atteso, il dato è già stato ricevuto e viene considerato un duplicato;
- se il numero è maggiore di quello atteso, significa che manca qualche segmento precedente: il dato può essere memorizzato temporaneamente in attesa dei segmenti mancanti.

Questo meccanismo permette di ricostruire correttamente il flusso anche quando i segmenti arrivano fuori ordine.

ACK e riscontro cumulativo

Il riscontro viene inviato con un Acknowledgement Number, o ACKn. L'ACKn indica il numero del prossimo byte che il ricevente si aspetta di ricevere.

Per esempio, se il ricevente ha ricevuto correttamente tutti i byte fino al numero 999, invia un ACK con valore 1000, per dire: "ho ricevuto tutto fino a 999, ora aspetto il byte 1000".

Il riscontro può essere cumulativo: un solo ACK può confermare la ricezione corretta di più segmenti consecutivi. Questo riduce il numero di messaggi di controllo necessari.

Il protocollo TCP

TCP, Transmission Control Protocol, è un protocollo di trasporto punto-punto, orientato alla connessione e affidabile. La comunicazione avviene tra due estremi, di solito un client e un server.

Le sue caratteristiche principali sono:

- connection oriented: prima dello scambio dei dati viene aperta una connessione;
- affidabile: gestisce ACK, ritrasmissioni, numerazione e controllo degli errori;
- sequenziale: consegna i dati all'applicazione nell'ordine corretto;
- full-duplex: permette trasmissione contemporanea in entrambe le direzioni;
- orientato al flusso: vede i dati come una sequenza continua di byte.

Dopo l'apertura della connessione avviene la comunicazione vera e propria. Alla fine, la connessione viene chiusa con un'apposita procedura di terminazione.

Segmento TCP

Il segmento TCP contiene un header più complesso di quello UDP, perché deve supportare affidabilità, controllo della connessione e controllo del flusso.

I campi principali sono:

Campo	Funzione
Source Port	Porta del processo mittente
Destination Port	Porta del processo destinatario
Sequence Number	Numero del primo byte del segmento
Acknowledgement Number	Prossimo byte atteso dal ricevente
Header Length	Lunghezza dell'header TCP
Flags	Bit di controllo della connessione
Window Size	Dimensione della finestra di ricezione
Checksum	Controllo degli errori
Urgent Pointer	Usato con dati urgenti
Options	Parametri opzionali, come MSS

Le flag più importanti sono:

- SYN: richiesta di apertura della connessione;
- ACK: conferma di ricezione;
- FIN: richiesta di chiusura ordinata della connessione;

- RST: reset immediato della connessione;
- PSH: richiesta di consegna rapida dei dati all'applicazione;
- URG: segnala la presenza di dati urgenti.

MSS e MTU

MSS, Maximum Segment Size, indica la massima dimensione del corpo dati, cioè del payload, che può essere inserito in un segmento TCP.

Nelle reti Ethernet IPv4 il valore tipico della MTU, Maximum Transmission Unit, è 1500 byte. Se si sottraggono 20 byte di header IP e 20 byte di header TCP, si ottiene una MSS tipica di 1460 byte.

La MSS riguarda quindi solo i dati TCP, mentre la MTU riguarda la dimensione massima del frame/pacchetto trasportabile sul mezzo di rete.

Apertura della connessione TCP: three-way handshaking

TCP apre una connessione tramite three-way handshaking, cioè uno scambio iniziale di tre messaggi che permette a client e server di sincronizzare i numeri di sequenza e concordare i parametri della connessione.

La procedura è:

1. SYN: il client invia un segmento con flag SYN e un numero di sequenza iniziale;
2. SYN-ACK: il server risponde con SYN e ACK, confermando il SYN del client e inviando il proprio numero di sequenza iniziale;
3. ACK: il client conferma il SYN del server.

Dopo questi tre passaggi la connessione è stabilita e può iniziare il trasferimento dei dati.

Il three-way handshaking serve per evitare comunicazioni non sincronizzate e per assicurare che entrambi gli host siano pronti a trasmettere e ricevere.

Protocollo a finestre scorrevoli

TCP usa il meccanismo delle finestre scorrevoli per trasmettere più segmenti senza dover attendere un ACK dopo ogni singolo invio.

La finestra indica quanti byte o segmenti possono essere inviati senza ricevere conferma. Quando arrivano gli ACK, la finestra "scorre" in avanti e permette di inviare nuovi dati.

Questo meccanismo migliora l'efficienza, perché mantiene attiva la trasmissione, e consente anche il controllo di flusso: il destinatario può comunicare quanto spazio ha disponibile nel buffer tramite il campo Window Size.

Se il ricevente ha poca memoria disponibile, può ridurre la finestra; se invece può ricevere più dati, può aumentarla.

Ritrasmissione e gestione del time-out

Quando TCP invia un segmento, attiva un timer. Se l'ACK non arriva entro il tempo previsto dal RTO, il segmento viene considerato perso e viene ritrasmesso.

La ritrasmissione può avvenire anche quando il mittente riceve segnali che indicano la probabile perdita di un segmento, per esempio ACK duplicati. In ogni caso, lo scopo è ricostruire un flusso completo e

ordinato.

La gestione del time-out è importante per bilanciare affidabilità e prestazioni: TCP deve recuperare i dati persi senza appesantire inutilmente la rete con troppe ritrasmissioni.

Chiusura della connessione TCP

La chiusura della connessione può avvenire in due modi:

- handshake a tre vie: quando la chiusura avviene contemporaneamente dalle due parti;
- handshake a quattro vie: quando una parte chiude prima dell'altra.

Nel caso più comune, la chiusura a quattro vie avviene così:

1. un host invia FIN per dire che non deve più trasmettere dati;
2. l'altro host risponde con ACK;
3. quando anche il secondo host ha finito di trasmettere, invia FIN;
4. il primo host risponde con ACK.

Questa procedura esiste perché TCP è full-duplex: le due direzioni della comunicazione sono indipendenti, quindi una parte può smettere di trasmettere mentre l'altra deve ancora inviare dati.

Differenze principali tra TCP e UDP

Aspetto	TCP	UDP
Connessione	Connection oriented	Connectionless
Affidabilità	Garantisce consegna ordinata	Non garantisce consegna
Velocità	Più lento per l'overhead	Più veloce e leggero
Header	Più complesso	Semplice, 8 byte
Ritrasmissioni	Sì	No
Ordine dei dati	Garantito	Non garantito
Uso tipico	Web, posta, FTP, SSH	Streaming, DNS, VoIP, giochi online

Parole chiave

Segmento, PDU, SAP, porta, socket, multiplexing, demultiplexing, buffering, affidabilità, servizio inaffidabile, connection oriented, connectionless, ACK, riscontro cumulativo, Sequence Number, RTT, RTO, finestra scorrevole, Window Size, QoS, UDP, TCP, MSS, MTU, checksum, ICMP port unreachable, SYN, FIN, RST, three-way handshaking.

Da integrare con le presentazioni

- Esempi completi di domande tipiche d'esame.
-

Scheda 2

MODULO II - Lo strato di applicazione

Obiettivo del modulo

Comprendere i principali servizi dello strato applicativo e il modo in cui permettono agli utenti e ai sistemi di usare la rete: configurazione automatica, navigazione web, trasferimento file, posta elettronica e risoluzione dei nomi.

Argomenti da sviluppare

- Configurazione dei sistemi con DHCP.
- WWW e HTTP.
- FTP.
- Posta elettronica: web mail e pop mail.
- SMTP, POP3 e IMAP.
- Standard MIME.
- DNS.

Schema sintetico iniziale

Lo strato di applicazione contiene i protocolli usati direttamente dai servizi di rete. Ogni protocollo risolve un bisogno specifico: DHCP assegna automaticamente la configurazione IP, HTTP permette la consultazione delle pagine web, FTP consente il trasferimento dei file, SMTP/POP3/IMAP gestiscono la posta elettronica e DNS traduce i nomi di dominio in indirizzi IP.

DHCP semplifica la configurazione dei client perché assegna parametri come indirizzo IP, subnet mask, gateway predefinito e server DNS. DNS, invece, è fondamentale per rendere utilizzabili i nomi simbolici al posto degli indirizzi numerici.

UNITA 1 - Il livello delle applicazioni

Un'applicazione di rete è un insieme di programmi che lavorano su più computer collegati tra loro tramite Internet o tramite una rete locale. Per questo viene anche chiamata applicazione distribuita.

Nel modello ISO/OSI il livello applicativo è quello più vicino all'utente finale: comprende i protocolli che permettono alle applicazioni di comunicare con applicazioni remote. Esempi di applicazioni di rete sono posta elettronica, Web, messaggistica istantanea, accesso a terminali remoti, condivisione file P2P, streaming, telefonia via Internet e videoconferenza.

Un processo è un programma in esecuzione su un host. Processi sullo stesso host possono comunicare tramite meccanismi del sistema operativo; processi su host diversi comunicano invece attraverso la rete, usando protocolli di livello applicazione e i servizi degli strati inferiori.

L'agente utente, o user agent, è l'interfaccia tra l'utente e l'applicazione di rete. Esempi:

- browser web per il WWW;
- client di posta per le e-mail;
- lettore audio/video per lo streaming.

Protocolli del livello applicazione

Un protocollo applicativo stabilisce:

- il formato dei messaggi scambiati;
- il significato dei messaggi;
- le azioni da eseguire quando un messaggio viene inviato o ricevuto;
- il modo in cui vengono usati i servizi del livello di trasporto.

Tra i protocolli applicativi più importanti ci sono:

- HTTP e HTTPS per il Web;
- FTP, FTPS e SFTP per il trasferimento di file;
- SMTP, POP3 e IMAP per la posta elettronica;
- DNS per la risoluzione dei nomi;
- DHCP per la configurazione automatica degli host;
- Telnet e SSH per l'accesso remoto.

Architetture delle applicazioni di rete

Quando si progetta un'applicazione di rete bisogna scegliere l'architettura, cioè il modo in cui sono organizzati i programmi che comunicano.

Architettura client-server

Nel modello client-server l'applicazione è divisa in due parti: client e server.

Il server:

- e di solito sempre attivo;
- ha un indirizzo IP fisso o comunque raggiungibile;
- fornisce un servizio ai client;
- può gestire molti client contemporaneamente;
- può essere realizzato tramite più macchine, cluster o server farm.

Il client:

- richiede un servizio al server;
- può contattare il server quando serve;
- può avere un indirizzo IP dinamico;
- normalmente non comunica direttamente con gli altri client.

Un esempio tipico è il WWW: il browser è il client, mentre il web server contiene pagine e risorse che vengono inviate su richiesta.

Quando le richieste sono molte, un solo server può non bastare. In questi casi si usano server virtuali, cluster o server farm per distribuire il carico e garantire continuità del servizio. Per l'utente il servizio può apparire come un unico hostname, anche se dietro ci sono più indirizzi IP e più server.

Architettura peer-to-peer, P2P

Nel modello peer-to-peer non esiste necessariamente un server centrale: ogni nodo, detto peer, può fornire e ricevere risorse. I dispositivi comunicano direttamente tra loro e la rete può adattarsi dinamicamente.

I vantaggi principali sono:

- scalabilità, perché il carico viene distribuito tra i peer;
- ridondanza, perché una risorsa può essere presente su più nodi;
- minore dipendenza da un server unico.

Gli svantaggi principali sono:

- minore controllo;
- gestione della sicurezza più complessa;
- maggiore difficoltà nel garantire affidabilità e qualità del servizio.

Un esempio è BitTorrent: i file vengono divisi in piccoli pezzi e ogni peer scarica parti del file mentre condivide le parti già ricevute. In questo modo il carico sul server originario si riduce e il download può diventare più veloce.

P2P centralizzato e ibrido

Nel P2P centralizzato esiste un server centrale, spesso chiamato directory server, che non memorizza i file ma mantiene informazioni su quali peer possiedono certe risorse. I peer conservano i dati, comunicano al server cosa condividono e permettono ad altri peer di scaricare le risorse. Un esempio storico è Napster.

Nel P2P ibrido alcuni nodi hanno un ruolo più importante e diventano super-peer. Questi super-peer aiutano nella ricerca o nel coordinamento, mentre lo scambio dei dati può avvenire tra peer. Esempi citati sono Skype ed eMule.

API e socket nel livello applicativo

Per comunicare in rete, un programma usa delle API, Application Programming Interface. Nel caso delle applicazioni Internet, un concetto fondamentale è quello di socket.

Una socket è un punto di comunicazione attraverso cui due processi, per esempio client e server, si scambiano messaggi. Lo sviluppatore controlla la parte applicativa, mentre il sistema operativo gestisce i dettagli del protocollo di trasporto, i buffer e le variabili della connessione.

Il concetto di socket collega direttamente il livello applicativo al livello di trasporto: l'applicazione invia e riceve dati attraverso la socket, mentre TCP o UDP si occupano del trasporto effettivo.

Quale servizio di trasporto richiede un'applicazione?

Le applicazioni non hanno tutti gli stessi bisogni. La scelta del protocollo di trasporto dipende dai requisiti del servizio.

I requisiti principali sono:

- perdita di dati: alcune applicazioni, come il trasferimento file, richiedono affidabilità al 100%; altre, come audio e video in tempo reale, possono tollerare piccole perdite;
- temporizzazione: applicazioni come VoIP, giochi online e videoconferenze richiedono ritardi bassi;
- ampiezza di banda: applicazioni multimediali possono richiedere una banda minima, mentre applicazioni elastiche, come la posta elettronica, usano la banda disponibile;
- sicurezza: alcune applicazioni richiedono integrità, autenticazione o cifratura dei dati.

Esempi:

Applicazione	Protocollo applicativo	Trasporto tipico
Posta elettronica	SMTP	TCP
Accesso remoto	Telnet/SSH	TCP
Web	HTTP/HTTPS	TCP
Trasferimento file	FTP	TCP
Streaming multimediale	Protocolli proprietari o standard specifici	TCP o UDP
Telefonia Internet	Protocolli VoIP	Tipicamente UDP

Il World Wide Web

Il World Wide Web, WWW, e l'insieme delle pagine e delle risorse collegate da link e accessibili tramite HTTP o HTTPS.

Il funzionamento di base e client-server:

1. l'utente inserisce un URL nel browser;
2. il browser, cioè il client, invia una richiesta al web server;
3. il server risponde inviando la risorsa richiesta;
4. il browser interpreta il contenuto e lo visualizza.

Una pagina web è composta da oggetti: spesso una pagina HTML iniziale e altri oggetti collegati, come immagini, fogli di stile, script o file multimediali.

Browser, web server, URI e URL

Il browser è lo user agent del Web. Le sue funzioni principali sono:

- instaurare una connessione TCP con il server;
- inviare richieste per ottenere le risorse;
- interpretare HTML e altri linguaggi lato client;
- visualizzare il contenuto in modo comprensibile all'utente;
- gestire la cache.

La cache del browser è uno spazio su disco in cui vengono salvate copie di pagine, immagini e altri oggetti già scaricati. Prima di richiedere una risorsa al server, il browser può controllare se è già disponibile in cache. Con il comando aggiorna/refresh l'utente può forzare una nuova richiesta al server.

Il web server è il software, in esecuzione su un server, che gestisce le richieste dei client e invia pagine o risorse web. Esempi di web server sono Apache, Nginx e IIS.

Una risorsa su Internet viene identificata da un URI, Uniform Resource Identifier. Un URL, Uniform Resource Locator, è un tipo di URI che specifica dove si trova la risorsa e come raggiungerla. Tutti gli URL sono URI, ma non tutti gli URI sono URL.

Esempio:

`https://www.scuola.it/info/corsi.html`

- `https` : protocollo usato;

- `www.scuola.it` : nome dell'host;
- `/info/corsi.html` : percorso e file della risorsa.

Il protocollo HTTP

HTTP, HyperText Transfer Protocol, è il protocollo di livello applicativo usato per trasferire risorse web da un server a un client. Nell'uso comune il client è il browser, mentre il server è il web server che ospita il sito.

HTTP gestisce:

- le richieste inviate dal client al server;
- le risposte inviate dal server al client;
- il trasferimento di pagine HTML, immagini, file CSS, script e altri oggetti web.

Il WWW può essere riassunto come l'insieme di tre elementi:

- URL, per identificare e localizzare le risorse;
- HTTP, per trasferire le risorse;
- HTML, per descrivere la struttura delle pagine web.

HTTP usa normalmente TCP. Il client apre una connessione TCP verso il server sulla porta 80, invia una richiesta HTTP, riceve una risposta HTTP e poi la connessione può essere chiusa o mantenuta aperta, a seconda della versione e della configurazione.

HTTP e stateless

HTTP è un protocollo stateless, cioè senza stato. Significa che, a livello di protocollo, ogni richiesta è indipendente dalle precedenti: il server non conserva automaticamente memoria di quello che è stato scambiato prima con lo stesso client.

Questa caratteristica rende HTTP semplice, ma per applicazioni web più complesse servono meccanismi aggiuntivi, come cookie e sessioni, che permettono di riconoscere un utente e mantenere informazioni tra più richieste.

Versioni di HTTP e connessioni

Le versioni principali citate sono:

- HTTP/1.0: usa connessioni non persistenti; dopo una richiesta e una risposta, la connessione TCP viene chiusa;
- HTTP/1.1: introduce l'uso comune di connessioni persistenti, quindi più richieste e risposte possono usare la stessa connessione TCP;
- HTTP/2: migliora le prestazioni con compressione degli header e multiplexing di più richieste/risposte sulla stessa connessione;
- HTTP/3: versione più recente, basata su QUIC invece che direttamente su TCP, pensata per ridurre la latenza e migliorare le prestazioni.

Con HTTP/1.0, se una pagina contiene un file HTML e molte immagini, possono essere necessarie più connessioni TCP. Con HTTP/1.1 la stessa connessione può restare aperta e trasportare più coppie richiesta/risposta, riducendo il tempo complessivo.

Il pipelining, previsto in HTTP/1.1, permette al client di inviare più richieste prima di aver ricevuto tutte le risposte. Le risposte devono però arrivare nello stesso ordine delle richieste.

Messaggi HTTP: richiesta e risposta

HTTP funziona con uno schema request-response:

1. il client invia una richiesta;
2. il server interpreta la richiesta;
3. il server restituisce una risposta con un codice di stato e, spesso, un corpo contenente la risorsa richiesta.

Una richiesta HTTP contiene in genere:

- request line, con metodo, risorsa richiesta e versione HTTP;
- header, cioè righe con informazioni aggiuntive;
- body opzionale, usato ad esempio con POST.

Una risposta HTTP contiene in genere:

- status line, con versione HTTP, codice di stato e frase descrittiva;
- header opzionali;
- body opzionale, spesso contenente la pagina HTML o la risorsa richiesta.

Esempio semplificato di risposta:

```
HTTP/1.1 200 OK
Content-Type: text/html
Content-Length: 6821

<html>...</html>
```

Metodi HTTP

Un metodo HTTP è un comando che il client invia al server per indicare quale operazione vuole eseguire sulla risorsa.

Metodo	Significato
GET	Richiede una risorsa, per esempio una pagina o un'immagine
HEAD	Richiede solo gli header, senza il body della risorsa
POST	Invia dati al server, spesso tramite un form
PUT	Carica o sostituisce una risorsa sul server, se autorizzato
DELETE	Richiede la cancellazione di una risorsa, se autorizzato
OPTIONS	Chiede quali metodi o opzioni sono supportati
TRACE	Metodo diagnostico per tracciare la richiesta
CONNECT	Richiede una connessione tramite proxy, spesso per creare un tunnel

GET è il metodo più comune: viene usato quando si clicca un link o si inserisce un URL nel browser. POST viene usato spesso quando si inviano dati tramite un modulo, per esempio login, ricerca o registrazione.

PUT e DELETE sui server pubblici sono normalmente disabilitati o protetti, per evitare che utenti non autorizzati possano modificare o cancellare risorse.

Codici di stato HTTP

Il codice di stato è un numero di tre cifre presente nella risposta del server. La prima cifra indica la classe della risposta.

Classe	Significato
1xx	Informational: risposta provvisoria
2xx	Successful: richiesta ricevuta, compresa e accettata
3xx	Redirection: servono altre azioni del client
4xx	Client error: errore nella richiesta del client
5xx	Server error: errore del server

Esempi importanti:

- 200 OK: richiesta eseguita correttamente;
- 201 Created: risorsa creata;
- 301 Moved Permanently: risorsa spostata in modo permanente;
- 400 Bad Request: richiesta sintatticamente errata;
- 401 Unauthorized: richiesta autenticazione;
- 403 Forbidden: accesso vietato;
- 404 Not Found: risorsa non trovata;
- 405 Method Not Allowed: metodo non consentito;
- 500 Internal Server Error: errore interno del server;
- 501 Not Implemented: metodo non implementato.

HTTPS

HTTPS, HyperText Transfer Protocol Secure, è la versione sicura di HTTP. Dal punto di vista dei messaggi applicativi il funzionamento rimane simile a HTTP, ma la comunicazione tra browser e server viene protetta tramite TLS.

HTTPS serve soprattutto a:

- cifrare i dati scambiati, impedendo a terzi di leggerli facilmente;
- autenticare il server tramite un certificato digitale;
- proteggere credenziali, dati personali, pagamenti e moduli inviati online.

In pratica, quando un sito usa HTTPS, il browser comunica con il server usando un canale protetto. I dettagli di TLS, certificati digitali e crittografia vengono approfonditi nei moduli di sicurezza.

Autenticazione HTTP

HTTP può prevedere anche meccanismi di autenticazione per limitare l'accesso a certe risorse.

Il caso più semplice è che il server risponda con il codice 401 Unauthorized e chieda al browser username e password. Se le credenziali sono corrette, il server invia la risorsa.

Tecniche citate:

- filtro su indirizzi IP: consente o nega l'accesso in base all'indirizzo IP del client;
- Basic Authentication: invia username e password codificati in Base64; è semplice ma non sicura se non usata con HTTPS;
- Digest Authentication: non invia direttamente la password, ma un digest calcolato con funzioni hash.

Per il ripasso basta ricordare che l'autenticazione HTTP controlla l'accesso alle risorse, mentre HTTPS protegge il canale di comunicazione.

Il protocollo FTP

FTP, File Transfer Protocol, è un protocollo applicativo usato per trasferire file tra computer collegati in rete. Permette di condividere file di testo o binari anche tra sistemi diversi.

FTP usa TCP per garantire un trasferimento affidabile. La particolarità di FTP è che usa due connessioni TCP:

- porta 21: canale di controllo, usato per comandi e risposte;
- porta 20: canale dati, usato per il trasferimento dei file nella modalità attiva.

Per usare FTP servono:

- un FTP server, che mette a disposizione file e directory;
- un FTP client, che permette all'utente di collegarsi, autenticarsi e trasferire file.

Operazioni comuni:

- download: copia di un file dal server al client;
- upload: copia di un file dal client al server;
- cancellazione di file;
- creazione di directory;
- visualizzazione e gestione delle cartelle remote.

L'accesso può essere autenticato, con username e password, oppure anonimo. L'accesso anonimo viene usato per download pubblici ma offre un livello di sicurezza basso.

FTP attivo e FTP passivo

FTP può funzionare in modalità attiva o passiva.

Nella modalità attiva il client apre la connessione di controllo verso il server, ma poi è il server ad aprire la connessione dati verso il client. Questo può creare problemi con i firewall lato client, perché il tentativo del server di aprire una connessione in ingresso può essere bloccato.

Per questo motivo oggi è spesso preferita la modalità passiva. In modalità passiva il client apre sia la connessione di controllo sia la connessione dati verso il server. Se anche il server ha un firewall, bisogna configurare un intervallo di porte, di solito superiori a 1024, per accettare le connessioni dati passive.

Sicurezza: FTP, FTPS e SFTP

FTP tradizionale non cifra i dati. Questo significa che username, password, comandi, risposte e file possono essere intercettati tramite sniffing.

Per aumentare la sicurezza si usano alternative cifrate:

- FTPS: estende FTP aggiungendo cifratura SSL/TLS;
- SFTP: servizio di trasferimento file basato su SSH, diverso da FTP ma usato con scopo simile.

FTPS protegge credenziali e dati tramite cifratura; l'algoritmo viene negoziato con il server e spesso i client mostrano un simbolo di lucchetto per indicare il trasferimento sicuro.

Tipo di accesso	Descrizione	Sicurezza
Anonimo	Accesso senza credenziali personali, usato per download pubblici	Bassa
Autenticato	Richiede username e password, con privilegi assegnati	Media
Sicuro	FTPS o SFTP, con trasferimento cifrato	Alta

Comandi FTP principali

I comandi FTP vengono inviati come testo ASCII sul canale di controllo.

Comando	Significato
USER username	Invia il nome utente
PASS password	Invia la password
LIST o ls	Mostra i file della directory corrente
RETR file o get file	Scarica un file dal server
STOR file o put file	Carica un file sul server
cd directory	Cambia directory remota
pwd	Mostra la directory remota corrente
binary	Imposta trasferimento binario
ascii	Imposta trasferimento ASCII
quit o bye	Chiude la connessione FTP

Esempi di codici di risposta:

- 331: username corretto, password richiesta;
- 125: connessione dati già aperta, trasferimento in avvio;
- 425: impossibile aprire la connessione dati;
- 452: errore nella scrittura del file.

FTP in Packet Tracer

In Packet Tracer una configurazione FTP tipica prevede:

1. assegnare indirizzi IP a client, server e dispositivi di rete;
2. configurare gateway e DNS sul server, se necessari;

3. aprire il server e abilitare il servizio FTP;
4. creare uno o più utenti con permessi adeguati, per esempio lettura, scrittura, cancellazione, rinomina e lista;
5. dal PC client aprire il Command Prompt;
6. digitare `ftp indirizzo_server`;
7. inserire username e password;
8. usare comandi come `put`, `get`, `ls`, `rename`, `quit`.

Esercizio tipico: creare file su PC1, caricarli sul server FTP, rinominarli, accedere da PC2 e scaricarli, verificando che siano presenti sul secondo PC.

UNITA 2 - Posta elettronica, DNS e Telnet/SSH

La posta elettronica è uno dei servizi di rete più diffusi. Il principio è simile alla posta ordinaria: un utente invia un messaggio all'indirizzo di un altro utente, che lo riceve nella propria casella.

I vantaggi principali dell'e-mail sono:

- velocità di invio e ricezione;
- costo ridotto, legato solo alla connessione;
- possibilità di inviare lo stesso messaggio a più destinatari;
- possibilità di allegare file di vario tipo, come documenti, immagini, video o programmi.

Indirizzo e account di posta

Per usare la posta elettronica servono un indirizzo e una casella postale. La casella è uno spazio sul server del provider in cui vengono depositati automaticamente i messaggi in arrivo.

Un account di posta comprende:

- indirizzo e-mail;
- userid o identificativo utente;
- password;
- server di invio;
- server di ricezione.

Un indirizzo e-mail ha la forma:

`nomeutente@dominio`

Esempio:

`mariorossi@tin.it`

- `mariorossi`: nome utente, univoco all'interno del dominio;
- `@`: simbolo "at", cioè "presso";
- `tin.it`: dominio del provider o dell'organizzazione.

In genere sono ammessi punti e underscore, mentre non sono ammessi spazi, caratteri accentati e molti simboli speciali.

Struttura di un messaggio e-mail

Un messaggio di posta è formato da intestazione e corpo.

Nell'intestazione possono comparire campi come:

- From: mittente;
- To: destinatario principale;
- Cc: destinatari in copia conoscenza;
- Ccn/Bcc: destinatari in copia nascosta;
- Date: data di spedizione;
- Reply-To: indirizzo a cui rispondere;
- Subject: oggetto del messaggio.

Dopo l'header c'è una linea vuota e poi il body, cioè il testo vero e proprio del messaggio.

Web mail, POP mail e IMAP mail

L'accesso alla posta può avvenire in due modi principali:

- web mail: si usa un browser e ci si collega al sito del provider, per esempio Gmail o Outlook;
- POP mail o IMAP mail: si usa un client di posta, detto MUA, come Outlook, Thunderbird o l'app Mail dello smartphone.

La web mail è comoda perché permette l'accesso da qualsiasi computer connesso a Internet. I messaggi non vengono scaricati localmente: restano sul server e vengono gestiti tramite HTTP/HTTPS dal browser.

POP3, Post Office Protocol versione 3, permette al client di scaricare i messaggi dal server sul computer locale. Di solito, dopo il download, i messaggi vengono eliminati dal server, anche se si può scegliere di lasciarne una copia.

IMAP, Internet Message Access Protocol, permette invece di gestire i messaggi direttamente sul server. Le cartelle restano sincronizzate tra più dispositivi, quindi è più comodo quando si usa la stessa casella da computer, smartphone e web mail.

Aspetto	POP3	IMAP
Gestione messaggi	Scarica i messaggi sul client	Mantiene e sincronizza i messaggi sul server
Uso da più dispositivi	Meno comodo	Molto comodo
Spazio sul server	Si libera più facilmente	Viene usato di più
Accesso offline	Possibile sui messaggi scaricati	Possibile con sincronizzazione locale
Porte	110, oppure 995 con SSL/TLS	143, oppure 993 con SSL/TLS

SMTP, POP3, IMAP, MUA, MTA e MDA

La posta elettronica usa più componenti.

Il MUA, Mail User Agent, è il programma usato dall'utente per scrivere, inviare, leggere e gestire i messaggi. Esempi sono Outlook, Thunderbird o un'interfaccia web mail.

Il MTA, Mail Transport Agent, è il servizio server che trasferisce i messaggi tra server di posta. Se non può consegnare direttamente il messaggio al server del destinatario, lo inoltra fino a raggiungere il server

corretto.

Il MDA, Mail Delivery Agent, riceve i messaggi dall'MTA, li filtra, per esempio contro spam e virus, e li deposita nelle caselle dei destinatari.

I protocolli principali sono:

- SMTP, Simple Mail Transfer Protocol: invio dei messaggi e trasferimento tra server;
- POP3: scaricamento della posta dal server al client;
- IMAP: gestione e sincronizzazione della posta sul server.

Porte principali:

Protocollo	Uso	Porte
SMTP	Invio e trasferimento posta	25, 465 con SSL, 587 con STARTTLS
POP3	Ricezione/scaricamento posta	110, 995 con SSL/TLS
IMAP	Gestione remota della posta	143, 993 con SSL/TLS

Schema di invio e ricezione di una mail

Esempio: Mario invia un messaggio a Laura.

1. Mario scrive il messaggio con il proprio MUA.
2. Il MUA invia il messaggio al server SMTP di Mario.
3. Il server SMTP di Mario trasferisce il messaggio al server di posta di Laura.
4. Il server di Laura verifica che esista la casella del destinatario.
5. Il messaggio viene depositato nella mailbox di Laura.
6. Laura accede alla casella tramite POP3, IMAP o web mail.

SMTP usa TCP per avere trasferimento affidabile. Lo scambio avviene tramite comandi e risposte testuali, con tre fasi: handshaking, trasferimento di uno o più messaggi e chiusura.

MIME

MIME, Multipurpose Internet Mail Extensions, è uno standard che estende la posta elettronica, nata inizialmente per gestire testo semplice in ASCII.

Grazie a MIME è possibile inviare:

- allegati multipli;
- messaggi lunghi;
- caratteri diversi dall'ASCII, come UTF-8;
- testi formattati;
- file binari, immagini, audio, video ed eseguibili.

I dati binari o multimediali devono essere convertiti in una forma trasmissibile tramite posta, per esempio usando la codifica Base64. Essere compatibile MIME è una caratteristica del MUA.

Il DNS, Domain Name System

DNS, Domain Name System, è il servizio che traduce i nomi simbolici, facili da ricordare per gli utenti, in indirizzi IP, usati dai dispositivi di rete.

Esempi di nomi simbolici:

- `www.google.com`;
- `www.tulliobuzzi.edu.it`;
- `mario.rossi@unina.it`.

I router non possono instradare i pacchetti usando direttamente questi nomi: hanno bisogno degli indirizzi IP. Per questo serve la risoluzione dei nomi.

Il DNS comprende:

- un database distribuito e gerarchico;
- una gerarchia di server DNS, detti name server;
- un protocollo applicativo per la comunicazione tra host e server DNS.

Normalmente DNS usa UDP sulla porta 53. In alcuni casi, per esempio trasferimenti di zona o risposte molto grandi, può usare TCP sulla stessa porta.

Funzioni del DNS

Le funzioni principali del DNS sono:

- tradurre nomi simbolici in indirizzi IP;
- effettuare la risoluzione inversa, cioè da IP a nome;
- gestire alias;
- aiutare nella distribuzione del carico.

Un alias è un nome alternativo associato a un host. Per esempio, un sito può avere un nome canonico e più alias che puntano allo stesso servizio. Questo semplifica l'uso e permette di cambiare l'indirizzo reale senza modificare il nome usato dagli utenti.

Per il bilanciamento del carico, un nome può essere associato a più indirizzi IP. Il DNS può rispondere ruotando l'ordine degli indirizzi: questa tecnica è detta DNS Round Robin. In questo modo client diversi possono collegarsi a server diversi senza accorgersi della distribuzione.

Domini e gerarchia DNS

I nomi DNS sono organizzati gerarchicamente e le parti sono separate da punti.

Esempio:

`lab1.tulliobuzzi.edu.it`

- `lab1`: nome dell'host;
- `tulliobuzzi.edu.it`: dominio;
- `.it`: dominio di primo livello nazionale;
- `.edu.it`: sottodominio riservato alle istituzioni scolastiche italiane.

Nel DNS la parte più significativa è a destra. I nomi non distinguono maiuscole e minuscole. Ogni componente può arrivare a 63 caratteri, mentre il nome completo non può superare 255 caratteri.

La gerarchia dei server DNS comprende:

- root server: sono al vertice e conoscono gli indirizzi dei server TLD;
- server TLD, Top-Level Domain: gestiscono domini come `.com`, `.it`, `.org`, `.edu`;

- server autorevoli, o authoritative name server: hanno autorità su una zona e forniscono la risposta finale;
- server DNS locali: non appartengono strettamente alla gerarchia, ma ricevono le query degli host e interrogano gli altri server per conto del client.

In genere un dominio ha almeno un server primario e uno secondario per ridondanza e affidabilità.

Risoluzione dei nomi, query e caching

Quando un client vuole conoscere l'indirizzo IP di un nome, usa un programma detto resolver. Il resolver interroga il server DNS configurato sul client, di solito il DNS locale del provider o della rete.

Esempio semplificato per `www.amazon.com`:

1. il client chiede al DNS locale l'indirizzo di `www.amazon.com`;
2. il DNS locale interroga un root server;
3. il root server indica i server TLD per `.com`;
4. il DNS locale interroga un server TLD `.com`;
5. il TLD indica il server autorevole per `amazon.com`;
6. il server autorevole restituisce l'IP di `www.amazon.com`;
7. il DNS locale restituisce la risposta al client.

Le query possono essere:

- ricorsive: il server interrogato si occupa di trovare la risposta completa;
- iterative: il server risponde con la migliore informazione disponibile, indicando quale altro server interrogare.

DNS usa il caching per ridurre ritardi e traffico. Quando un server DNS impara una mappatura, la memorizza per un certo periodo. Scaduto il tempo di validità, l'informazione viene eliminata o aggiornata. Il parametro che stabilisce la durata della cache è il TTL, Time To Live.

Record DNS

Le informazioni DNS sono memorizzate come Resource Record, RR. Un messaggio DNS può contenere più record.

Record comuni:

Record	Significato
A	Associa un nome a un indirizzo IPv4
AAAA	Associa un nome a un indirizzo IPv6
CNAME	Alias verso un nome canonico
MX	Server di posta responsabile per un dominio
NS	Name server autorevole per una zona
PTR	Risoluzione inversa da IP a nome
TXT	Informazioni testuali, spesso usate anche per verifiche e sicurezza

Per verificare il DNS si possono usare strumenti come `nslookup`, `host` e `dig`.

Telnet e SSH

Telnet è un protocollo applicativo client-server basato su TCP che permette di aprire una sessione bidirezionale tra due host. Dopo la connessione, il client può lavorare sulla macchina remota tramite linea di comando come se fosse collegato direttamente.

Telnet usa la porta 23 e richiede che sul server sia in esecuzione un servizio in ascolto, come `telnetd`.

Il problema principale di Telnet è la sicurezza: la comunicazione non è cifrata, quindi dati, comandi e password viaggiano in chiaro e possono essere intercettati.

Per questo Telnet è stato quasi completamente sostituito da SSH, Secure Shell. SSH offre le funzioni di Telnet ma aggiunge:

- cifratura della comunicazione;
- autenticazione sicura;
- possibilità di autenticazione a chiave pubblica;
- protezione dell'intera sessione.

SSH è oggi uno standard di fatto per l'amministrazione remota dei sistemi.

Esempi di comandi:

Comando	Uso
<code>telnet host</code>	Connessione Telnet alla porta 23
<code>telnet host porta</code>	Connessione Telnet a una porta specifica
<code>ssh hostname</code>	Accesso SSH con l'utente corrente
<code>ssh utente@hostname</code>	Accesso SSH con un utente specifico

Comandi di rete utili

Alcuni comandi utili per diagnosi e prove di rete:

Comando	Funzione
<code>hostname</code>	Mostra il nome del computer
<code>ping host</code>	Verifica la raggiungibilità di un host
<code>tracert host</code> o <code>traceroute host</code>	Mostra il percorso verso una destinazione
<code>host nome</code>	Interroga il DNS
<code>dig nome</code>	Interroga il DNS in modo dettagliato
<code>dig -x IP</code>	Risoluzione inversa
<code>nslookup nome</code>	Verifica record DNS
<code>mail indirizzo</code>	Invio semplice di posta da terminale
<code>ftp host</code>	Avvia un client FTP
<code>wget URL</code>	Scarica file dal Web in modo non interattivo

Parole chiave

Applicazione distribuita, processo, user agent, protocollo applicativo, client-server, server farm, virtualizzazione, peer-to-peer, P2P centralizzato, P2P ibrido, super-peer, API, socket, HTTP, HTTPS, stateless, request, response, metodo HTTP, GET, POST, PUT, DELETE, codice di stato, cookie, sessione, WWW, browser, web server, URI, URN, URL, cache, FTP, FTPS, SFTP, upload, download, modalita attiva, modalita passiva, e-mail, account, mailbox, MUA, MTA, MDA, SMTP, POP3, IMAP, MIME, Base64, DNS, resolver, name server, root server, TLD, authoritative server, DNS locale, cache DNS, TTL, record A, AAAA, CNAME, MX, NS, PTR, Telnet, SSH, DHCP, lease, risoluzione dei nomi.

Da integrare con le presentazioni

- Sequenza DORA del DHCP.
 - Esempi Packet Tracer su DHCP, DNS, SMTP/POP3 e WWW.
-

Scheda 3

MODULO III - Le Virtual Local Area Network (VLAN)

Obiettivo del modulo

Studiare come le VLAN permettono di dividere logicamente una rete locale, migliorando organizzazione, sicurezza e gestione del traffico broadcast.

Argomenti da sviluppare

- VLAN untagged.
- VLAN tagged secondo IEEE 802.1Q.
- Access port e trunk port.
- Protocollo VTP.
- Inter-VLAN tradizionale.
- Inter-VLAN Router-on-a-stick.

Schema sintetico iniziale

Una VLAN è una rete locale virtuale: consente di separare dispositivi collegati allo stesso switch fisico come se appartenessero a reti diverse. Questa separazione riduce i domini di broadcast e permette di organizzare la rete per reparti, funzioni o livelli di sicurezza.

Le porte access appartengono a una sola VLAN e sono usate di solito per collegare host finali. Le porte trunk trasportano invece traffico di più VLAN, usando il tagging 802.1Q per identificare a quale VLAN appartiene ogni frame.

Per far comunicare VLAN diverse serve un dispositivo di livello 3, come un router o uno switch multilayer. Le due soluzioni principali studiate sono l'inter-VLAN tradizionale e il Router-on-a-stick.

UNITA 1 - Le Virtual LAN

Con il termine VLAN, Virtual LAN, si indica un insieme di tecnologie che permettono di creare più reti logiche partendo da una sola rete fisica. In pratica, usando gli stessi switch e gli stessi collegamenti, si possono ottenere più LAN separate tra loro.

Ogni VLAN si comporta come una rete locale indipendente:

- i frame broadcast restano confinati nella VLAN;
- la comunicazione di livello 2 avviene solo tra dispositivi della stessa VLAN;
- host appartenenti a VLAN diverse non comunicano direttamente;
- per comunicare tra VLAN diverse serve routing di livello 3.

Lo standard IEEE 802.1Q definisce il modo in cui più VLAN possono condividere la stessa infrastruttura fisica, soprattutto quando il traffico deve attraversare collegamenti tra switch.

Ogni VLAN è identificata da:

- un nome;
- un numero chiamato VID, VLAN Identifier;

- un proprio blocco di indirizzi IP.

I VLAN ID utilizzabili normalmente vanno da 1 a 4094. I valori 0 e 4095 sono riservati.

Scopo e vantaggi delle VLAN

Le VLAN vengono usate per migliorare organizzazione, prestazioni e sicurezza della rete.

I vantaggi principali sono:

- risparmio: non serve costruire una nuova rete fisica per ogni reparto o gruppo;
- prestazioni: il traffico broadcast resta confinato e non si propaga a tutta la rete;
- sicurezza: un host di una VLAN non vede direttamente il traffico delle altre VLAN;
- flessibilità: spostare un dispositivo può richiedere solo una riconfigurazione logica dello switch, senza cambiare la topologia fisica.

Esempio: in un'azienda si possono creare VLAN separate per amministrazione, studenti, laboratori, ospiti e gestione degli apparati.

Access port e trunk port

Le porte di uno switch possono essere configurate principalmente in due modi.

Una access port è una porta collegata a dispositivi finali, come PC, stampanti o server, che appartengono a una sola VLAN. I frame che entrano o escono da una access port sono normalmente non taggati.

Una trunk port è una porta usata per collegare switch tra loro, oppure uno switch a un router o a uno switch multilayer. Su una trunk port possono transitare frame appartenenti a più VLAN. Per distinguere a quale VLAN appartiene ogni frame si usa il tagging 802.1Q.

Tipo di porta	Uso principale	VLAN trasportate	Frame
Access port	Collegamento di host finali	Una sola VLAN	Non taggati
Trunk port	Collegamento tra apparati di rete	Più VLAN	Taggati 802.1Q

VLAN port based, o untagged

Nelle VLAN port based, dette anche untagged, ogni porta dello switch viene assegnata staticamente a una VLAN. Lo switch viene quindi diviso logicamente in più switch separati.

Il funzionamento è semplice:

- ingress: un frame che entra da una porta appartiene alla VLAN associata a quella porta;
- forwarding: il frame viene inoltrato solo verso porte della stessa VLAN;
- egress: il frame esce senza tag, cioè senza modifiche visibili per l'host finale.

Le VLAN untagged non richiedono che gli host conoscano lo standard 802.1Q. Questo è importante perché PC, stampanti e dispositivi comuni normalmente inviano e ricevono frame Ethernet standard, senza tag VLAN.

Il limite delle VLAN solo port based emerge quando bisogna collegare più switch: se non si usa il trunking, servirebbe un collegamento fisico separato per ogni VLAN da estendere tra gli switch.

VLAN tagged e standard 802.1Q

Le VLAN tagged risolvono il problema del collegamento tra switch. Con lo standard 802.1Q più VLAN possono condividere lo stesso link fisico, chiamato trunk link.

Quando un frame deve attraversare un trunk, lo switch aggiunge un tag 802.1Q che indica la VLAN di appartenenza. Lo switch di destinazione legge il tag e sa in quale VLAN inoltrare il frame.

Il tag 802.1Q aggiunge 4 byte al frame Ethernet. I campi principali sono:

- TPID, Tag Protocol Identifier: identifica il frame come frame 802.1Q, con valore 0x8100;
- TCI, Tag Control Information: contiene informazioni di controllo;
- priority: bit per eventuale priorità del traffico;
- CFI/DEI: campo di compatibilità/indicazione;
- VID: 12 bit che contengono il VLAN ID.

Su un trunk:

1. un host invia un frame non taggato allo switch;
2. lo switch associa il frame alla VLAN della porta access;
3. se il frame deve passare su un trunk, lo switch aggiunge il tag;
4. lo switch di arrivo legge il tag;
5. prima di consegnare il frame a un host finale, il tag viene rimosso.

Nessun frame di una VLAN deve essere inoltrato verso porte appartenenti a un'altra VLAN, a meno che non intervenga un dispositivo di livello 3.

Porte ibride, PVID e apparati non 802.1Q

Lo standard 802.1Q prevede anche porte che possono essere associate a una VLAN in modo untagged e ad altre VLAN in modo tagged. In questo caso si parla di porta o link ibrido.

Se un frame arriva senza tag, viene associato alla VLAN configurata come untagged sulla porta. Questa VLAN prende il nome di PVID, Port VLAN ID o Private VLAN ID nel materiale.

Gli apparati che non supportano 802.1Q devono essere collegati a porte configurate in modalità untagged, così possono continuare a usare frame Ethernet ordinari.

VLAN 1, VLAN dati, VLAN nativa e VLAN di gestione

Alcuni tipi di VLAN importanti sono:

Tipo di VLAN	Descrizione
VLAN predefinita, o VLAN 1	VLAN iniziale degli switch; di default tutte le porte appartengono a VLAN 1
VLAN dati	Trasporta il traffico degli utenti finali, come PC e stampanti
VLAN nativa	VLAN usata su trunk per i frame non taggati
VLAN di gestione	Usata per amministrare switch, router e altri apparati
VLAN voce	Usata per telefoni IP e traffico voce, spesso con QoS

La VLAN 1 non può essere eliminata ed è presente di default. Per sicurezza, nelle reti reali si tende a non usare VLAN 1 per il traffico utente o per la gestione, ma a creare VLAN dedicate.

La VLAN nativa riguarda i collegamenti trunk: se una porta trunk riceve frame senza tag, li associa alla VLAN nativa. Su apparati Cisco, se non configurata diversamente, spesso la VLAN nativa è la VLAN 1.

La VLAN di gestione deve essere riservata al traffico amministrativo, come SSH o Telnet verso gli apparati di rete, e non dovrebbe essere usata per il traffico degli utenti finali.

UNITA 2 - VTP e inter-VLAN routing

Una VLAN può essere estesa su due o più switch tramite collegamenti trunk. In reti grandi, configurare manualmente le stesse VLAN su ogni switch può diventare complesso e può portare facilmente a errori.

Per questo Cisco ha introdotto VTP, VLAN Trunking Protocol.

Il protocollo VTP

VTP è un protocollo proprietario Cisco che permette di gestire e mantenere coerente la configurazione delle VLAN in una rete di switch.

L'idea è questa: le VLAN vengono configurate su uno switch e le informazioni vengono distribuite agli altri switch dello stesso dominio VTP. In questo modo si riduce la configurazione manuale.

Un dominio VTP è un insieme di switch che si scambiano messaggi VTP, detti advertisement, per sincronizzare le informazioni sulle VLAN. Uno switch può appartenere a un solo dominio VTP alla volta.

Parametri importanti:

- VTP version: versione del protocollo, 1, 2 o 3;
- VTP domain name: nome del dominio VTP;
- VTP mode: ruolo dello switch;
- configuration revision: numero di revisione della configurazione;
- password VTP, se configurata;
- elenco delle VLAN.

Il comando di verifica citato è:

```
show vtp status
```

Modalità VTP

VTP può funzionare in tre modalità principali:

Modalità	Caratteristiche
Server	Permette di creare, modificare ed eliminare VLAN e distribuisce le modifiche
Client	Riceve e applica le modifiche VTP, poi le inoltra agli altri switch
Transparent	Non applica le modifiche VTP alla propria configurazione, ma può inoltrare i messaggi

Di default, molti switch Cisco partono in modalità server.

La configuration revision è un contatore che aumenta ogni volta che viene fatta una modifica alle VLAN. Gli switch client applicano una nuova configurazione solo se il numero di revisione ricevuto è maggiore di quello attuale.

Per questo bisogna fare attenzione quando si aggiunge uno switch usato in una rete: se ha un numero di revisione alto e una configurazione errata, potrebbe propagare informazioni sbagliate. Prima di inserirlo conviene riportare la revisione a zero.

Configurazione VTP: idea generale

Per un VTP server, i passaggi generali sono:

1. verificare lo stato VTP con `show vtp status`;
2. configurare il nome del dominio con `vtp domain nome`;
3. configurare versione e password, se richieste;
4. creare le VLAN;
5. configurare i collegamenti trunk.

Per un VTP client:

1. verificare che la configurazione sia pulita e la revision sia a 0;
2. impostare la modalita client con `vtp mode client`;
3. configurare eventuale password;
4. verificare le porte trunk;
5. configurare le porte access per gli host.

Inter-VLAN routing

Le VLAN separano la rete a livello 2. Questo significa che host in VLAN diverse non possono comunicare direttamente solo tramite switch di livello 2.

Per permettere la comunicazione tra VLAN diverse serve un dispositivo di livello 3, come:

- un router;
- uno switch multilayer.

Questa comunicazione prende il nome di inter-VLAN routing.

Inter-VLAN tradizionale

Nell'inter-VLAN routing tradizionale il router viene collegato allo switch con piu interfacce fisiche, una per ogni VLAN che deve comunicare.

Caratteristiche:

- ogni interfaccia fisica del router e collegata a una VLAN;
- ogni interfaccia del router ha un indirizzo IP appartenente alla rete della VLAN;
- le porte dello switch verso il router sono configurate come access port;
- l'indirizzo del router nella VLAN viene usato come gateway predefinito dagli host.

Esempio: se esistono VLAN 10 e VLAN 20, il router usa due interfacce fisiche: una con IP della rete VLAN 10 e una con IP della rete VLAN 20.

Il limite principale e la scalabilita: servono molte porte fisiche sul router e sullo switch, una per ogni VLAN.

Router-on-a-stick

Router-on-a-stick e una soluzione piu efficiente: il router usa una sola interfaccia fisica collegata allo switch tramite una porta trunk.

L'interfaccia fisica del router viene divisa in subinterfacce virtuali, una per ogni VLAN. Ogni subinterfaccia:

- e associata a una VLAN tramite incapsulamento 802.1Q;

- ha un indirizzo IP appartenente alla rete di quella VLAN;
- funziona come gateway per gli host di quella VLAN.

La porta dello switch collegata al router deve essere configurata in modalita trunk, perche deve trasportare traffico di piu VLAN.

Esempio concettuale:

- VLAN 10: rete 192.168.10.0/24, gateway 192.168.10.1;
- VLAN 20: rete 192.168.20.0/24, gateway 192.168.20.1;
- il router ha una sola interfaccia fisica, ma due subinterfacce, una per VLAN 10 e una per VLAN 20.

Router-on-a-stick riduce il numero di collegamenti fisici, ma tutto il traffico tra VLAN passa attraverso la stessa interfaccia fisica, quindi bisogna considerare le prestazioni.

Confronto tra inter-VLAN tradizionale e Router-on-a-stick

Aspetto	Inter-VLAN tradizionale	Router-on-a-stick
Collegamenti router-switch	Una porta per ogni VLAN	Un solo trunk
Porte switch verso router	Access port	Trunk port
Configurazione router	Interfacce fisiche separate	Subinterfacce virtuali
Scalabilita	Bassa se le VLAN sono molte	Migliore
Uso tipico	Reti piccole o esempi didattici	Reti con piu VLAN su trunk

VLAN in Packet Tracer

In Packet Tracer gli esercizi sulle VLAN di solito richiedono di:

1. creare le VLAN sugli switch;
2. assegnare le porte access alle VLAN corrette;
3. configurare i trunk tra switch;
4. verificare che host nella stessa VLAN comunichino;
5. verificare che host in VLAN diverse non comunichino senza routing;
6. configurare inter-VLAN routing tradizionale o Router-on-a-stick;
7. impostare il gateway corretto sui PC;
8. testare la comunicazione con `ping`.

Parole chiave

VLAN, Virtual LAN, dominio di broadcast, VID, VLAN ID, 802.1Q, access port, trunk port, access link, trunk link, VLAN untagged, VLAN tagged, tag 802.1Q, TPID, TCI, PVID, VLAN 1, default VLAN, native VLAN, VLAN dati, VLAN di gestione, VLAN voce, VTP, VTP domain, VTP server, VTP client, VTP transparent, configuration revision, inter-VLAN routing, inter-VLAN tradizionale, Router-on-a-stick, subinterface, gateway.

Da integrare con le presentazioni

- Comandi Packet Tracer/Cisco per creare VLAN e trunk.

- Configurazione delle subinterfacce nel Router-on-a-stick.
 - Esempi di progettazione con piu reparti.
-

Scheda 4

MODULO IV - La sicurezza nelle reti: la protezione dei dati

Obiettivo del modulo

Comprendere le tecniche crittografiche usate per proteggere i dati, garantendo riservatezza, integrità, autenticazione e non ripudio.

Argomenti da sviluppare

- Crittografia e algoritmi crittografici.
- Crittografia a chiave simmetrica.
- Algoritmi DES e AES.
- Crittografia a chiave asimmetrica.
- Chiave pubblica e chiave privata.
- Algoritmo RSA.
- Schema Diffie-Hellman per lo scambio delle chiavi.
- Crittografia ibrida.
- Funzione di hash.
- Firma digitale.
- Certificati digitali.
- Certification Authority, PKI e software PGP.

Schema sintetico iniziale

La crittografia serve a trasformare un messaggio leggibile in un messaggio cifrato, comprensibile solo da chi possiede la chiave corretta. Nella crittografia simmetrica la stessa chiave viene usata per cifrare e decifrare; nella crittografia asimmetrica esistono invece due chiavi collegate: una pubblica e una privata.

DES e AES sono algoritmi simmetrici: AES è oggi considerato più sicuro e moderno. RSA è un algoritmo asimmetrico usato per cifratura, autenticazione e firma digitale. Diffie-Hellman permette a due soggetti di concordare una chiave condivisa anche su un canale non sicuro.

La crittografia ibrida combina i vantaggi dei due approcci: usa la crittografia asimmetrica per scambiare una chiave e la crittografia simmetrica per cifrare i dati in modo efficiente.

UNITA 1 - Introduzione alla sicurezza e crittografia simmetrica

Con la diffusione di Internet e dei servizi digitali è aumentata la quantità di dati scambiati in rete. Di conseguenza è aumentata anche la necessità di proteggerli da intercettazioni, modifiche e accessi non autorizzati.

La sicurezza informatica comprende misure organizzative e tecnologiche che permettono a ogni utente autorizzato di accedere solo ai servizi e alle informazioni previste, nei modi e nei tempi stabiliti.

Secondo la triade CIA, gli obiettivi principali della sicurezza sono:

- Confidentiality, o segretezza: le informazioni devono essere accessibili solo a chi è

autorizzato;

- Integrity, o integrità: i dati non devono essere modificati senza autorizzazione;
- Availability, o disponibilità: gli utenti autorizzati devono poter accedere ai servizi quando ne hanno bisogno.

Ai tre obiettivi si aggiungono spesso:

- autenticazione: confermare l'identità delle parti che comunicano;
- non ripudio: impedire che il mittente possa negare di aver inviato un certo messaggio.

Minacce e attacchi

Una minaccia è una potenziale azione o condizione che può compromettere sicurezza, integrità o disponibilità di sistemi, reti o dati. Un attacco è un'azione concreta che viola la sicurezza.

Gli attacchi possono essere:

- passivi: intercettano o monitorano le comunicazioni senza modificarle;
- attivi: modificano il flusso dei dati o creano un falso flusso.

Esempi:

Attacco	Obiettivo colpito	Descrizione
Eavesdropping	Segretezza	Intercettazione di informazioni riservate
Tampering	Integrità	Modifica o sostituzione dei dati in transito
Masquerading	Autenticità	Impersonificazione di un altro soggetto
Denial of Service	Disponibilità	Uso eccessivo di risorse per rendere un servizio non disponibile

Un sistema sicuro non è un sistema impossibile da violare: significa che l'attacco viene reso molto più difficile e costoso. Le misure di sicurezza devono essere proporzionate al valore delle risorse da proteggere.

Crittografia: concetti base

La crittografia è l'insieme delle tecniche che permettono di trasformare un testo leggibile in un testo cifrato, e poi di riportarlo alla forma originale tramite decifratura.

Gli elementi principali sono:

- testo in chiaro, o plain-text: messaggio leggibile;
- cifrario, o cipher: algoritmo usato per cifrare e decifrare;
- chiave: parametro segreto usato dall'algoritmo;
- crittogramma: messaggio cifrato.

La cifratura applica un algoritmo al testo in chiaro usando una chiave. La decifratura usa la chiave corretta per recuperare il testo originale.

Le tecniche di cifratura possono basarsi su:

- sostituzione: ogni simbolo viene sostituito con un altro;
- trasposizione: i simboli vengono riordinati senza cambiarli.

Principio di Kerckhoffs/Shannon

Il principio di Kerckhoffs/Shannon afferma che la sicurezza di un sistema crittografico non deve dipendere dal segreto dell'algoritmo, ma solo dal segreto della chiave.

In altre parole, anche se un attaccante conosce l'algoritmo usato, non deve riuscire a decifrare il messaggio senza possedere la chiave.

Questo principio è alla base della crittografia moderna: gli algoritmi possono essere pubblici, studiati e verificati, mentre la chiave deve rimanere segreta.

Crittografia simmetrica

La crittografia simmetrica, detta anche a chiave privata o a chiave segreta, usa la stessa chiave per cifrare e decifrare.

Il mittente e il destinatario devono quindi conoscere la stessa chiave segreta. La robustezza del sistema dipende dalla forza dell'algoritmo e dalla segretezza della chiave.

Condizioni necessarie:

- algoritmo crittografico robusto;
- distribuzione sicura della chiave;
- conservazione sicura della chiave da parte di mittente e destinatario.

Vantaggi:

- velocità elevata;
- efficienza anche su grandi quantità di dati;
- adatta alla cifratura di comunicazioni e file.

Svantaggi:

- problema dello scambio della chiave;
- se la chiave viene scoperta, tutta la comunicazione è compromessa;
- in una rete con molti utenti servono molte chiavi diverse.

Il problema principale è quindi la distribuzione della chiave: mittente e destinatario devono concordarla tramite un canale sicuro, ma spesso proprio il canale sicuro non è disponibile.

Cifrari a flusso e cifrari a blocchi

Gli algoritmi simmetrici si dividono principalmente in cifrari a flusso e cifrari a blocchi.

I cifrari a flusso, o stream cipher, cifrano il messaggio bit per bit o byte per byte. Generano un flusso di bit pseudo-casuali, detto keystream, che viene combinato con il testo in chiaro, spesso tramite XOR.

Caratteristiche dei cifrari a flusso:

- elaborano i dati in modo continuo;
- sono veloci;
- sono adatti a trasmissioni in tempo reale, come audio e video;
- richiedono un keystream sicuro e non prevedibile.

Il keystream viene generato da un PRNG, Pseudorandom Number Generator, a partire da un seed segreto. Se destinatario e mittente hanno stesso algoritmo e stesso seed, possono generare lo stesso flusso e cifrare/decifrare correttamente.

I cifrari a blocchi, o block cipher, dividono i dati in blocchi di lunghezza fissa e cifrano ogni blocco come un'unità. Gli algoritmi moderni usano più round, cioè più passaggi ripetuti, spesso con chiavi derivate da una chiave principale tramite un key schedule.

Esempi:

- DES e AES sono cifrari a blocchi;
- Salsa20 e ChaCha20 sono cifrari a flusso.

Cifrari classici: Cesare, sostituzione, Vigenere, Vernam

Il cifrario di Cesare è un semplice cifrario a sostituzione: ogni lettera viene sostituita con un'altra spostata di un certo numero di posizioni nell'alfabeto. Il valore dello spostamento è la chiave.

Esempio: con chiave 3, A diventa D, B diventa E e così via. È un algoritmo molto debole, perché le chiavi possibili sono poche e può essere attaccato facilmente.

Il cifrario a sostituzione monoalfabetica generalizza Cesare: ogni lettera viene sostituita secondo un alfabeto cifrante arbitrario. Anche se le chiavi possibili sono molte, resta vulnerabile all'analisi statistica delle frequenze delle lettere.

Il cifrario di Vigenere usa più alfabeti cifranti e una parola chiave. La stessa lettera del testo in chiaro può quindi essere cifrata in modi diversi a seconda della posizione. Fu considerato molto robusto per molto tempo, ma può essere attaccato quando la chiave si ripete.

Il cifrario di Vernam, o One Time Pad, usa una chiave:

- completamente casuale;
- lunga almeno quanto il messaggio;
- usata una sola volta;
- tenuta segreta.

In queste condizioni è teoricamente inviolabile se l'attaccante conosce solo il testo cifrato. Il problema è pratico: generare, distribuire e conservare chiavi così lunghe e sicure è molto difficile.

Crittoanalisi e forza bruta

La crittoanalisi studia tecniche per decifrare un messaggio senza conoscere la chiave. Spesso sfrutta caratteristiche statistiche del linguaggio, ripetizioni o debolezze dell'algoritmo.

Un attacco a forza bruta prova tutte le chiavi possibili finché non trova quella corretta. La sua difficoltà dipende dallo spazio delle chiavi: più la chiave è lunga, più combinazioni devono essere provate.

Per questo nella crittografia moderna la lunghezza della chiave è fondamentale. Un algoritmo può essere noto, ma deve avere uno spazio delle chiavi così grande da rendere impraticabile la ricerca esaustiva.

DES

DES, Data Encryption Standard, è stato per molti anni uno degli algoritmi simmetrici a blocchi più importanti.

Per molto tempo è stato considerato sicuro, ma con l'aumento della potenza di calcolo la sua chiave è diventata troppo corta. Il problema principale di DES è proprio la lunghezza della chiave, che rende possibile un attacco a forza bruta con risorse sufficienti.

Nel 1998 l'Electronic Frontier Foundation dimostro che DES poteva essere forzato in tempi pratici usando hardware dedicato. Per questo oggi DES non e considerato adeguato per la protezione moderna dei dati.

AES

AES, Advanced Encryption Standard, conosciuto anche come Rijndael, e oggi uno degli algoritmi simmetrici piu usati.

E un cifrario a blocchi con blocchi da 128 bit e chiavi da 128, 192 o 256 bit. E stato adottato dal NIST nel 2001 come standard per la cifratura simmetrica.

AES e considerato robusto perche:

- e veloce;
- e efficiente;
- resiste agli attacchi noti piu importanti;
- ha chiavi abbastanza lunghe da rendere impraticabile la forza bruta.

Il funzionamento interno usa piu round. Per AES con chiave a 128 bit si usano 10 round. Ogni round comprende trasformazioni come:

- SubBytes: sostituzione non lineare dei byte;
- ShiftRows: spostamento delle righe della matrice;
- MixColumns: combinazione dei byte nelle colonne;
- AddRoundKey: combinazione con la chiave del round tramite XOR.

Non serve conoscere a memoria tutti i dettagli matematici: per l'esame e importante ricordare che AES e un cifrario simmetrico a blocchi moderno, molto piu sicuro di DES e usato in moltissimi sistemi reali.

UNITA 2 - Crittografia asimmetrica, RSA e crittografia ibrida

La crittografia simmetrica e veloce, ma ha un problema fondamentale: mittente e destinatario devono scambiarsi una chiave segreta senza che nessuno la intercetti.

Diffie e Hellman proposero una soluzione rivoluzionaria: usare meccanismi matematici che permettono di ottenere una chiave condivisa anche comunicando su un canale non sicuro.

Diffie-Hellman

Diffie-Hellman non e un cifrario per cifrare direttamente messaggi: e uno schema per stabilire una chiave segreta condivisa tra due soggetti.

L'idea e che Alice e Bob combinano:

- informazioni pubbliche, visibili anche a un eventuale intercettatore;
- informazioni private, conosciute solo da ciascuno di loro.

Alla fine entrambi ottengono la stessa chiave segreta, mentre chi osserva la comunicazione non riesce a ricostruirla in tempi pratici. La sicurezza si basa sulla difficolta di risolvere alcuni problemi matematici, come il logaritmo discreto.

Questa chiave condivisa puo poi essere usata con un algoritmo simmetrico, come AES, per cifrare i dati veri e propri.

Crittografia asimmetrica o a chiave pubblica

La crittografia asimmetrica usa due chiavi diverse ma collegate:

- chiave pubblica: può essere distribuita a tutti;
- chiave privata: deve restare segreta e conosciuta solo dal proprietario.

Le proprietà principali sono:

- dalla chiave pubblica non si deve poter risalire alla chiave privata in tempi pratici;
- ciò che viene cifrato con una chiave può essere decifrato solo con l'altra chiave della coppia;
- per inviare un messaggio segreto a qualcuno, si usa la sua chiave pubblica;
- il destinatario decifra il messaggio con la propria chiave privata.

Esempio: se Anna vuole inviare un messaggio riservato a Bruno, cifra il messaggio con la chiave pubblica di Bruno. Solo Bruno, con la propria chiave privata, può decifrarlo.

Il problema diventa: come essere sicuri che una certa chiave pubblica appartenga davvero a Bruno? La risposta è l'uso di certificati digitali e Certification Authority.

Vantaggi e svantaggi della crittografia asimmetrica

Vantaggi:

- non serve condividere prima una chiave segreta;
- la chiave pubblica può essere distribuita liberamente;
- permette riservatezza, autenticazione e firma digitale;
- semplifica la comunicazione sicura tra soggetti che non si conoscono.

Svantaggi:

- è molto più lenta della crittografia simmetrica;
- richiede chiavi lunghe e calcoli complessi;
- serve un sistema affidabile per certificare le chiavi pubbliche.

Per questo, nella pratica, la crittografia asimmetrica viene spesso usata solo per scambiare una chiave simmetrica o per firmare, mentre i dati veri e propri vengono cifrati con algoritmi simmetrici.

RSA

RSA è uno degli algoritmi asimmetrici più famosi. Il nome deriva dai suoi ideatori: Rivest, Shamir e Adleman.

La sicurezza di RSA si basa sulla difficoltà di fattorizzare numeri molto grandi. È facile moltiplicare due numeri primi grandi, ottenendo un numero n ; e invece molto difficile, partendo da n , risalire ai due fattori primi originari.

RSA comprende due parti:

- generazione delle chiavi;
- cifratura e decifratura.

Nella generazione delle chiavi:

1. si scelgono due numeri primi molto grandi p e q ;
2. si calcola $n = p * q$;

3. si calcola la funzione di Eulero $\phi(n) = (p - 1)(q - 1)$;
4. si sceglie un esponente pubblico e ;
5. si calcola l'esponente privato d ;
6. la chiave pubblica e la coppia (e, n) ;
7. la chiave privata e la coppia (d, n) .

Per l'esame non e necessario saper svolgere tutti i calcoli: e importante capire che RSA usa una chiave pubblica per cifrare o verificare e una chiave privata per decifrare o firmare.

Nelle applicazioni reali i numeri usati sono molto grandi. Chiavi troppo corte non sono piu sicure; chiavi piu lunghe aumentano la sicurezza ma rendono i calcoli piu pesanti.

Crittografia ibrida

La crittografia ibrida unisce i vantaggi della crittografia simmetrica e asimmetrica.

L'idea e:

- usare la crittografia asimmetrica per scambiare in modo sicuro una chiave di sessione;
- usare la crittografia simmetrica, piu veloce, per cifrare i dati.

Esempio:

1. Anna genera una chiave casuale di sessione;
2. Anna cifra la chiave di sessione con la chiave pubblica di Bruno;
3. Bruno decifra la chiave di sessione con la propria chiave privata;
4. da quel momento Anna e Bruno usano la chiave di sessione con un algoritmo simmetrico.

Questo sistema e usato in molti protocolli reali perche evita il problema dello scambio della chiave e mantiene buone prestazioni.

UNITA 3 - Sistemi di autenticazione, firma digitale e certificati

Non sempre serve mantenere segreto un documento. A volte e piu importante garantire:

- autenticita: il documento proviene davvero da chi dice di averlo inviato;
- integrita: il documento non e stato modificato;
- non ripudio: il mittente non puo negare di averlo inviato.

Queste garanzie possono essere ottenute con la firma digitale.

Firma digitale

La firma digitale e l'equivalente informatico della firma su carta. Viene usata per sottoscrivere documenti digitali e, in determinati contesti, ha valore legale.

Si basa sulla crittografia asimmetrica:

- il firmatario usa la propria chiave privata;
- chiunque puo verificare la firma usando la chiave pubblica del firmatario.

La firma digitale:

- autentica l'origine dei dati;
- garantisce l'integrita del documento;

- collega il documento al soggetto che lo ha firmato.

La firma digitale può essere usata con dispositivi fisici, come smart card o token USB, oppure con sistemi di firma remota, SPID e codici OTP. In ambito italiano si incontrano anche CNS e CIE per l'accesso ai servizi digitali.

Funzioni di hash

Poiché gli algoritmi asimmetrici sono lenti, non si firma direttamente l'intero documento. Prima si calcola una sua impronta digitale tramite una funzione di hash.

Una funzione di hash prende dati di qualunque lunghezza e produce una stringa di lunghezza fissa, detta digest o impronta.

Proprietà importanti:

- unidirezionalità: dato il documento è facile calcolare l'hash, ma dall'hash deve essere difficile risalire al documento;
- resistenza alle collisioni: deve essere estremamente difficile trovare due documenti diversi con la stessa impronta.

Esempi di funzioni di hash:

- MD5: oggi vulnerabile e non raccomandato per usi critici;
- SHA-1: non più considerato sicuro;
- SHA-2 e SHA-3: famiglie moderne ancora usate.

Generazione della firma digitale

Il processo di firma avviene in tre passaggi:

1. si applica una funzione di hash al documento, ottenendo il digest;
2. il digest viene cifrato con la chiave privata del firmatario;
3. la firma viene allegata al documento, spesso insieme al certificato digitale del firmatario.

In questo modo la firma è legata:

- al documento, perché dipende dal suo hash;
- al firmatario, perché viene generata con la sua chiave privata.

Nei sistemi di firma italiani si possono incontrare file firmati con estensione `.p7m`.

Verifica della firma digitale

Chi riceve un documento firmato verifica la firma così:

1. usa la chiave pubblica del firmatario, ottenuta dal certificato digitale, per decifrare la firma e recuperare il digest originale;
2. calcola di nuovo l'hash del documento ricevuto;
3. confronta i due digest.

Se i digest coincidono, il documento non è stato modificato e la firma corrisponde alla chiave privata associata alla chiave pubblica del firmatario.

La firma digitale da sola non garantisce la riservatezza: un documento firmato può essere leggibile. Se serve anche segretezza, il documento deve essere anche cifrato.

Certificati digitali

Un certificato digitale è un file con validità temporale limitata che collega l'identità di un soggetto alla sua chiave pubblica.

Serve a risolvere il problema fondamentale della crittografia asimmetrica: come posso sapere che una chiave pubblica appartiene davvero a una certa persona o a un certo server?

Un certificato digitale contiene in genere:

- informazioni sul soggetto, persona o server;
- chiave pubblica del soggetto;
- numero di serie;
- periodo di validità;
- informazioni sulla Certification Authority;
- firma digitale della CA.

Il certificato attesta che le informazioni contenute sono state verificate da un'autorità fidata.

Formati diffusi:

- certificati X.509, tipici delle PKI e dei certificati web;
- chiavi/certificati PGP o GPG, spesso usati per posta e file.

Certification Authority, RA e PKI

La Certification Authority, CA, è un ente fidato che rilascia, firma, sospende e revoca certificati digitali.

La CA firma i certificati con la propria chiave privata. I browser e i sistemi operativi possiedono già le chiavi pubbliche di molte CA fidate: in questo modo possono verificare se un certificato è autentico.

La Registration Authority, RA, si occupa dell'identificazione del soggetto che richiede il certificato. Dopo le verifiche, la CA può emettere il certificato.

La PKI, Public Key Infrastructure, è l'insieme di tecnologie, procedure e autorità che gestisce i certificati di chiave pubblica. Di solito ha una struttura gerarchica:

- root CA, al vertice, spesso con certificato self-signed;
- CA intermedie;
- certificati finali, associati a utenti, server o servizi.

Questa struttura crea una catena di fiducia: se mi fido della root CA, posso verificare le CA intermedie e poi il certificato finale.

Uso dei certificati nei server web

Quando un browser apre una connessione sicura con un server:

1. il client richiede una connessione protetta;
2. il server invia il proprio certificato digitale;
3. il browser verifica la firma del certificato usando la chiave pubblica della CA;
4. se la verifica è positiva, il browser considera autentica la chiave pubblica del server;

5. la chiave pubblica del server viene usata per stabilire una chiave di sessione;
6. i dati successivi vengono cifrati con la chiave di sessione.

Se il certificato è scaduto, non valido, autofirmato o emesso da una CA non riconosciuta, il browser mostra un avviso di sicurezza.

Richiesta di un certificato

La procedura tipica per ottenere un certificato è:

1. il richiedente genera una coppia di chiavi;
2. la chiave privata resta segreta sul suo dispositivo o server;
3. la chiave pubblica viene inserita in una CSR, Certificate Signing Request, insieme ai dati identificativi;
4. la RA verifica l'identità del richiedente;
5. la CA emette il certificato e lo firma con la propria chiave privata;
6. il certificato viene installato sul server o consegnato all'utente.

PGP/GPG e strumenti pratici

PGP, Pretty Good Privacy, e GPG, GNU Privacy Guard, sono strumenti usati per cifrare e firmare messaggi, e-mail e file tramite crittografia a chiave pubblica.

A differenza dei certificati X.509, che dipendono da CA e PKI, il mondo PGP/GPG può basarsi anche su modelli di fiducia diversi, come la fiducia tra utenti.

Esempi di strumenti citati:

- Kleopatra/Gpg4win per gestire chiavi OpenPGP e firmare/cifrare file o e-mail;
- 7-Zip o PeaZip per creare archivi cifrati;
- VeraCrypt per cifrare volumi o dischi;
- BitLocker e FileVault per cifatura integrata nei sistemi operativi;
- Bitwarden e KeePassXC per gestire password in modo sicuro.

Parole chiave

CIA triad, segretezza, integrità, disponibilità, autenticazione, non ripudio, minaccia, attacco passivo, attacco attivo, eavesdropping, tampering, masquerading, DoS, crittografia, testo in chiaro, crittogramma, cifrario, chiave, Kerckhoffs, crittografia simmetrica, chiave segreta, cifrario a flusso, keystream, PRNG, seed, XOR, cifrario a blocchi, Cesare, Vigenere, Vernam, One Time Pad, crittoanalisi, forza bruta, DES, AES, chiave pubblica, chiave privata, RSA, Diffie-Hellman, chiave di sessione, crittografia ibrida, hash, digest, MD5, SHA, firma digitale, smart card, token USB, OTP, certificato digitale, X.509, CA, RA, PKI, root CA, CSR, catena di fiducia, PGP, GPG.

Da integrare con le presentazioni

- Esempi con PGP/GPG in macchina virtuale.
-

Scheda 5

MODULO V - La sicurezza delle reti: la protezione della rete

Obiettivo del modulo

Analizzare le principali minacce ai sistemi informatici e le tecnologie usate per proteggere reti, servizi e comunicazioni.

Argomenti da sviluppare

- Segretezza, integrità e disponibilità.
- Sicurezza dei sistemi informatici e minacce.
- S/MIME e PGP nella posta elettronica.
- Protocollo SSL/TLS.
- HTTPS e scambio delle chiavi.
- Certificati digitali dei web server.
- Firewall e packet filtering.
- Stateful inspection.
- Deep inspection o proxy server.
- Bastion host.
- DMZ.
- Sicurezza in IP: protocollo IPsec.
- Reti private virtuali: VPN.
- Intranet ed extranet.

Schema sintetico iniziale

La sicurezza informatica si basa su tre concetti fondamentali: segretezza, integrità e disponibilità. La segretezza impedisce l'accesso non autorizzato alle informazioni, l'integrità garantisce che i dati non vengano modificati in modo illecito e la disponibilità assicura che sistemi e servizi siano accessibili quando necessario.

SSL/TLS protegge le comunicazioni tra client e server e viene usato da HTTPS. I firewall filtrano il traffico di rete applicando regole di sicurezza. Le tecniche possono essere più o meno profonde: packet filtering, stateful inspection e deep inspection.

La DMZ è una zona di rete separata in cui si collocano servizi esposti verso l'esterno, come web server o mail server, riducendo il rischio per la rete interna. Le VPN permettono invece di creare collegamenti sicuri su reti pubbliche.

UNITA 1 - Sicurezza nei sistemi informativi

La sicurezza nei sistemi informativi è diventata sempre più importante con l'evoluzione delle reti. Negli anni dei mainframe il rischio principale era l'accesso fisico non autorizzato. Con le LAN Ethernet e Internet sono comparsi rischi come sniffing, accessi remoti non autorizzati e attacchi ai servizi esposti.

Oggi, con cloud, smart working e dispositivi IoT, il perimetro aziendale non è più semplice da definire. Per questo si parla spesso di Zero Trust: non ci si fida automaticamente di un utente o di un dispositivo solo perché si trova "dentro" la rete, ma si verifica sempre identità, permessi e contesto.

Evoluzione delle minacce

Le minacce sono cambiate insieme alle architetture di rete:

- mainframe: sistemi centralizzati, rischio soprattutto fisico;
- LAN Ethernet: rischio di sniffing e intercettazione del traffico locale;
- Internet aperta: accessi remoti, scansioni, exploit, necessita di firewall e IDS/IPS;
- cloud e IoT: dati distribuiti, dispositivi numerosi, identità e autorizzazioni da gestire con attenzione.

Lo sniffing è un esempio classico: un attaccante usa strumenti come Wireshark per intercettare pacchetti di rete. Se protocolli come POP3, IMAP, FTP o HTTP vengono usati senza cifratura, username, password e dati possono viaggiare in chiaro. Le versioni sicure, come IMAPS, POP3S e HTTPS, usano TLS per rendere i dati non leggibili a chi intercetta.

Problemi di sicurezza nei sistemi informatici

I problemi di sicurezza non derivano solo da hacker esterni. Possono dipendere anche da guasti, errori umani o eventi fisici.

Problema	Rischio	Contromisure
Calamita naturali	Perdita dell'infrastruttura	Disaster Recovery Plan, backup offsite, cloud backup
Guasti hardware	Interruzione del servizio o perdita dati	RAID, UPS, server ridondanti
Errori del personale	Cancellazioni o configurazioni errate	formazione, backup, separazione sviluppo/produzione
Malware	Furto, cifratura o distruzione dei dati	antivirus, EDR, aggiornamenti
Accesso non autorizzato	Uso illecito di sistemi e dati	autenticazione, MFA, ACL, log

Due indicatori importanti nel disaster recovery sono:

- RTO, Recovery Time Objective: tempo massimo tollerabile di interruzione;
- RPO, Recovery Point Objective: quantità massima di dati che si accetta di perdere.

Una regola pratica per i backup è la regola 3-2-1: tre copie dei dati, su due supporti diversi, con una copia conservata fuori sede.

Malware moderno

Il malware comprende molti tipi di software dannoso:

- virus: si replica allegandosi a file o programmi;
- worm: si propaga autonomamente in rete;
- trojan: si presenta come software legittimo ma apre accessi non autorizzati;

- spyware: raccoglie dati dell'utente, come password o schermate;
- rootkit: nasconde la presenza dell'attaccante mantenendo privilegi elevati;
- ransomware: cifra i dati della vittima e chiede un riscatto.

Il ransomware è una delle minacce più gravi. Di solito entra tramite phishing o vulnerabilità non corrette, si propaga nella rete, cifra file e backup raggiungibili e poi chiede un pagamento per la chiave di decifratura.

Difese principali:

- backup offline e regola 3-2-1;
- aggiornamenti tempestivi;
- segmentazione della rete;
- formazione anti-phishing;
- EDR, Endpoint Detection and Response.

EDR, IDS e IPS

Un antivirus tradizionale confronta file e programmi con un database di firme note. Un EDR va oltre: analizza il comportamento dei processi e può bloccare azioni sospette anche se il malware non è ancora noto.

Esempio: se un programma inizia a cifrare centinaia di file in poco tempo, l'EDR può riconoscere un comportamento simile a un ransomware e bloccarlo.

IDS e IPS servono invece per il traffico di rete:

- IDS, Intrusion Detection System: osserva il traffico, rileva comportamenti sospetti e genera allarmi, ma non blocca direttamente;
- IPS, Intrusion Prevention System: si trova nel flusso del traffico e può bloccare pacchetti, connessioni o host sospetti.

Nelle reti moderne IDS e IPS sono spesso integrati in apparati di sicurezza più completi, come firewall di nuova generazione.

SGSI e ISO/IEC 27001

SGSI significa Sistema di Gestione della Sicurezza delle Informazioni. Non è un singolo software, ma un insieme di processi, politiche e controlli per proteggere le informazioni aziendali.

Lo standard ISO/IEC 27001:2022 definisce un modello per organizzare la sicurezza delle informazioni. Si basa sul ciclo di miglioramento continuo PDCA:

- Plan: definire perimetro, risorse critiche, rischi e contromisure;
- Do: applicare le misure previste, come policy, firewall, formazione e monitoraggio;
- Check: verificare con audit, analisi dei log e test se le misure funzionano;
- Act: correggere le non conformità e migliorare il sistema.

La sicurezza non è quindi un'attività conclusa una volta per tutte, ma un processo continuo.

GDPR e protezione dei dati personali

Il GDPR, Regolamento Europeo 2016/679, disciplina la protezione dei dati personali. In Italia il Garante per la Protezione dei Dati Personali vigila sul rispetto della normativa.

Principi importanti:

- Privacy by Design: la protezione dei dati va progettata fin dall'inizio del sistema;
- Privacy by Default: le impostazioni predefinite devono essere le più protettive;
- Data Breach Notification: una violazione rilevante va notificata al Garante entro 72 ore;
- diritti degli interessati: accesso, rettifica, cancellazione, portabilità, limitazione e opposizione al trattamento;
- DPO, Data Protection Officer: figura che supervisiona la conformità al GDPR in contesti dove è richiesta.

Per una traccia d'esame è utile collegare GDPR, backup, cifratura, controllo accessi e log.

Autenticazione moderna e MFA

L'autenticazione verifica l'identità di un utente. La sola password non basta più, perché può essere rubata con phishing, data breach, brute force, credential stuffing o keylogger.

MFA, Multi-Factor Authentication, richiede almeno due fattori:

- qualcosa che sai: password, PIN;
- qualcosa che hai: smartphone, token OTP, smart card, YubiKey;
- qualcosa che sei: impronta digitale, volto, voce.

Esempi:

- TOTP: codice temporaneo generato da app come Google Authenticator;
- SMS OTP: codice via SMS, semplice ma meno sicuro;
- hardware token: dispositivo fisico USB/NFC;
- passkey FIDO2/WebAuthn: autenticazione senza password basata su crittografia a chiave pubblica e biometria locale.

MFA riduce molto il rischio: anche se la password viene rubata, serve ancora il secondo fattore.

Sicurezza della posta elettronica

SMTP, nella sua forma base, non garantisce autenticazione forte del mittente e può essere usato per spoofing e phishing. Inoltre, senza TLS, i messaggi possono viaggiare in chiaro.

Soluzioni moderne:

- STARTTLS e SMTPS: cifrano il canale SMTP con TLS;
- IMAPS e POP3S: usano TLS per la ricezione della posta;
- SPF, DKIM e DMARC: standard anti-spoofing che verificano la legittimità del dominio mittente;
- S/MIME e PGP/GPG: permettono firma digitale e cifratura end-to-end dei messaggi.

S/MIME si basa su certificati X.509 rilasciati da CA ed è adatto ad ambienti aziendali strutturati. PGP/GPG è più decentralizzato, basato su chiavi generate dagli utenti e spesso su un modello di fiducia chiamato Web of Trust.

PGP in sintesi

PGP usa crittografia ibrida:

1. calcola l'hash del messaggio, per esempio con SHA-256;
2. firma il digest con la chiave privata del mittente;
3. comprime messaggio e firma;
4. cifra il contenuto con una chiave di sessione simmetrica, per esempio AES;
5. cifra la chiave di sessione con la chiave pubblica del destinatario.

Il destinatario esegue i passaggi inversi: decifra la chiave di sessione con la propria chiave privata, decifra il messaggio, decompone e verifica la firma con la chiave pubblica del mittente.

UNITA 2 - Sicurezza con TLS

TCP, IP e HTTP sono stati progettati per comunicare in modo affidabile, non per garantire la sicurezza. Senza protezioni, i dati possono essere letti, modificati o intercettati.

TLS, Transport Layer Security, aggiunge un livello di sicurezza tra applicazione e trasporto. Protegge protocolli come HTTP, SMTP, IMAP, POP3 e FTP senza dover cambiare la logica principale dell'applicazione.

TLS fornisce:

- cifratura dei dati;
- autenticazione del server tramite certificato;
- integrità dei messaggi;
- opzionalmente, autenticazione del client.

HTTPS è semplicemente HTTP sopra TLS.

Da SSL a TLS 1.3

SSL è il predecessore di TLS ed è oggi considerato deprecato.

Evoluzione principale:

- SSL 2.0 e SSL 3.0: deprecati per vulnerabilità;
- TLS 1.0 e TLS 1.1: deprecati;
- TLS 1.2: ancora usato, ma richiede configurazione attenta;
- TLS 1.3: standard moderno, più veloce e più sicuro.

TLS 1.3 migliora rispetto a TLS 1.2 perché:

- riduce l'handshake a 1 RTT;
- usa solo suite crittografiche moderne;
- rimuove compressione e algoritmi deboli;
- rende obbligatoria la forward secrecy.

RTT, Round Trip Time, è il tempo di andata e ritorno di un messaggio tra client e server. Ridurre il numero di RTT rende la connessione più rapida.

Forward secrecy significa che ogni sessione usa una chiave temporanea diversa. Se in futuro venisse rubata la chiave privata del server, il traffico registrato in passato non potrebbe essere decifrato, perché le chiavi di sessione passate non esistono più.

Handshake TLS 1.3

L'handshake TLS serve a concordare i parametri di sicurezza e stabilire una chiave di sessione.

Schema semplificato:

1. ClientHello: il client invia versione TLS supportata, cipher suite e parametri ECDHE;
2. ServerHello: il server sceglie i parametri, invia il certificato e prova la propria identità;
3. Finished del client: il client verifica tutto e conferma;
4. dati applicativi cifrati: il canale protetto e attivo.

In TLS 1.3 il certificato e alcuni messaggi dell'handshake sono già protetti rispetto alle versioni precedenti.

Certificati X.509 e verifica del server

Quando il browser si collega a un sito HTTPS, il server invia un certificato X.509. Il certificato contiene:

- nome del dominio;
- chiave pubblica del server;
- periodo di validità;
- firma digitale della CA che lo ha emesso.

Il browser verifica:

1. che la firma del certificato sia valida;
2. che la CA sia fidata;
3. che il dominio del certificato corrisponda al sito visitato;
4. che il certificato non sia scaduto;
5. che non sia stato revocato.

Se uno di questi controlli fallisce, il browser mostra un avviso di sicurezza.

TLS Record Layer

Dopo l'handshake, i dati applicativi vengono protetti dal TLS Record Layer.

Funzionamento:

1. i dati applicativi vengono divisi in frammenti;
2. ogni frammento diventa un record TLS;
3. il record viene cifrato, per esempio con AES o ChaCha20;
4. viene aggiunto un tag di autenticazione per verificare l'integrità;
5. il record cifrato viene consegnato a TCP.

Se un attaccante modifica anche un solo bit, il tag di autenticazione non corrisponde e il record viene scartato. I numeri di sequenza aiutano anche a prevenire attacchi replay.

HTTPS e HSTS

HTTPS cifra la comunicazione tra browser e server usando TLS. Però, se l'utente digita un indirizzo `http://`, la prima richiesta potrebbe partire in chiaro.

HSTS, HTTP Strict Transport Security, è un meccanismo con cui il server dice al browser di usare sempre HTTPS per quel dominio.

Esempio di header:

```
Strict-Transport-Security: max-age=31536000
```

Dopo aver ricevuto HSTS, il browser trasforma automaticamente richieste `http://` in `https://` prima di inviarle. Questo riduce il rischio di attacchi come SSL stripping, in cui un attaccante prova a mantenere la vittima su HTTP in chiaro mentre comunica in HTTPS con il server.

UNITA 3 - VPN, reti private virtuali

Una VPN, Virtual Private Network, è una rete privata virtuale che permette a host o reti in sedi diverse di comunicare in modo sicuro usando una rete pubblica, come Internet.

Una VPN deve garantire:

- riservatezza: il traffico viene cifrato, per esempio con AES;
- integrità: eventuali modifiche ai pacchetti vengono rilevate tramite hash o tag di autenticazione;
- autenticazione: solo utenti o dispositivi autorizzati possono entrare nel tunnel.

In passato, per collegare sedi aziendali lontane si usavano linee dedicate, costose ma con prestazioni prevedibili. Le VPN riducono i costi usando Internet come infrastruttura di trasporto, ma richiedono cifratura, autenticazione e tunneling per mantenere la sicurezza.

Esempio: un dipendente in aeroporto si collega alla VPN aziendale tramite Wi-Fi pubblico. Il traffico viene cifrato fino al VPN gateway dell'azienda e l'utente può accedere alle risorse interne come se fosse in ufficio.

Accesso a Internet con VPN

Quando si usa una VPN per navigare, il traffico passa prima dal server VPN:

1. il client cifra il traffico e lo invia al server VPN;
2. il server VPN lo decifra e inoltra la richiesta verso Internet;
3. il sito vede come mittente l'indirizzo IP del server VPN, non quello reale dell'utente.

Questo può proteggere l'utente su reti pubbliche e mascherare l'indirizzo IP. Se il sito usa HTTPS, il contenuto resta cifrato anche oltre il server VPN grazie a TLS.

Tunneling e modalità IPsec

Il tunneling consiste nell'incapsulare un pacchetto dentro un altro pacchetto. In questo modo il traffico originale può attraversare Internet come se viaggiasse dentro un canale privato.

IPsec può lavorare in due modalità:

Modalità	Caratteristiche	Uso tipico
Tunnel	Cifra e incapsula l'intero pacchetto IP originale in un nuovo pacchetto	Gateway-to-gateway, site-to-site
Trasporto	Cifra solo il payload, lasciando visibile l'header IP originale	Host-to-host

Nella modalita tunnel, i pacchetti interni reali vengono nascosti: su Internet si vedono gli indirizzi dei gateway VPN. Nella modalita trasporto, invece, gli indirizzi IP originali restano visibili e viene protetto soprattutto il contenuto.

Quando tra client e server c'e un NAT, IPsec puo usare NAT-T, NAT Traversal, su UDP porta 4500.

Protocolli VPN

Protocolli VPN principali:

Protocollo	Caratteristiche	Uso tipico
IPsec/IKEv2	Standard di livello 3, usa tunnel o trasporto, autenticazione con certificati	Aziende, site-to-site
OpenVPN	Basato su SSL/TLS, flessibile e multiplatforma	Accesso remoto e scenari misti
WireGuard	Moderno, veloce, semplice, usa crittografia recente	VPN moderne e configurazioni leggere

IPsec e uno standard storico e molto usato in ambito enterprise. OpenVPN e flessibile e puo usare porte configurabili. WireGuard e piu recente, ha codice ridotto e prestazioni molto elevate.

Scenari VPN

Le VPN possono essere usate in scenari diversi:

- Site-to-Site: collega due reti aziendali, per esempio sede centrale e filiale; di solito usa router o firewall come gateway e IPsec in modalita tunnel;
- End-to-Site: un singolo dispositivo remoto, come un laptop, si collega alla rete aziendale; tipico del telelavoro;
- End-to-End: due host comunicano direttamente tramite un canale cifrato.

Si distingue anche tra:

- VPN Intranet: collega sedi della stessa organizzazione;
- VPN Extranet: permette a soggetti esterni, come fornitori o partner, di accedere solo ad alcune risorse autorizzate.

Nelle VPN extranet e fondamentale combinare tunnel VPN, firewall e policy restrittive, perche un soggetto esterno non deve poter accedere a tutta la rete interna.

VPN ad accesso remoto, NAS e RADIUS

Una VPN ad accesso remoto richiede:

- un NAS o VPN gateway, cioe il punto di ingresso sicuro alla rete aziendale;
- un client VPN installato sul dispositivo dell'utente;
- un sistema di autenticazione, spesso centralizzato.

Il NAS, Network Access Server, puo delegare l'autenticazione a un server RADIUS.

RADIUS implementa il modello AAA:

- Authentication: verifica chi e l'utente;

- Authorization: stabilisce cosa puo fare e quali risorse puo raggiungere;
- Accounting: registra cosa ha fatto, durata della connessione, IP assegnato e traffico.

Una configurazione moderna usa spesso RADIUS insieme a MFA, certificati X.509 o sistemi come Active Directory.

Attacchi e difese nelle VPN

Possibili rischi:

- credential stuffing: uso di credenziali rubate da altri servizi;
- downgrade attack: tentativo di forzare protocolli o cifrature meno sicure;
- DNS leak: richieste DNS che escono fuori dal tunnel VPN;
- configurazioni errate del tunnel o del firewall.

Difese:

- MFA obbligatoria;
- protocolli aggiornati, come IKEv2, OpenVPN aggiornato o WireGuard;
- certificati X.509;
- patch regolari;
- monitoraggio dei log;
- policy firewall precise.

UNITA 4 - Firewall, proxy, ACL e DMZ

Una rete collegata a Internet deve essere protetta da accessi indesiderati, malware, attacchi avanzati e traffico non autorizzato.

Gli strumenti principali sono:

- firewall;
- proxy;
- ACL;
- DMZ;
- IDS/IPS e NGFW.

Firewall

Un firewall e un sistema di difesa perimetrale che controlla il traffico di rete in base a regole di sicurezza.

Principi fondamentali:

- deve essere l'unico punto di contatto tra rete interna ed esterna;
- solo il traffico autorizzato puo attraversarlo;
- deve essere configurato, aggiornato e monitorato con attenzione.

Il firewall decide quale traffico puo entrare o uscire in base alle policy. Non garantisce da solo che il traffico autorizzato sia sempre innocuo: per questo servono anche IDS/IPS, antivirus, EDR e controlli applicativi.

Personal firewall e network firewall

I firewall possono essere:

- personal firewall: proteggono un singolo host, controllando soprattutto il traffico in ingresso e in uscita dal computer;
- network firewall: si collocano tra LAN e Internet e filtrano il traffico di tutta la rete.

Nelle aziende si usano spesso firewall dedicati, fisici o virtuali, posti tra router, switch, server e zone di rete diverse.

Packet filtering firewall

Il packet filtering firewall analizza ogni pacchetto singolarmente, senza memoria dei pacchetti precedenti. Per questo si dice stateless.

Controlla campi come:

- indirizzo IP sorgente;
- indirizzo IP destinazione;
- porta sorgente;
- porta destinazione;
- protocollo, per esempio TCP, UDP o ICMP.

Le regole possono seguire due filosofie:

- default allow: tutto è permesso tranne ciò che viene vietato;
- default deny: tutto è bloccato tranne ciò che viene autorizzato.

L'approccio più sicuro è default deny.

Azioni tipiche:

- accept: permette il pacchetto;
- deny/reject: scarta e può notificare l'errore;
- discard/drop: scarta silenziosamente.

Le ACL sono uno strumento concreto per implementare regole di packet filtering.

Limiti:

- non analizza il contenuto applicativo;
- può essere aggirato da IP spoofing se configurato male;
- non rileva attacchi che passano su porte consentite, come 80 o 443;
- regole complesse sono difficili da verificare.

Stateful inspection firewall

Lo stateful inspection firewall tiene traccia dello stato delle connessioni.

Quando una connessione viene autorizzata, il firewall crea una voce in una tabella di stato con informazioni come:

- IP e porta sorgente;
- IP e porta destinazione;
- stato della connessione;
- informazioni della sequenza TCP.

I pacchetti successivi appartenenti a una connessione già registrata vengono accettati più facilmente. I pacchetti non coerenti vengono verificati o scartati.

Vantaggio: è più sicuro di un filtro stateless perché controlla il contesto della connessione. Limite: non analizza in profondità il contenuto applicativo.

Application proxy firewall e reverse proxy

Un application proxy firewall lavora a livello applicativo. Si interpone tra client e server, riceve le richieste, le analizza e poi le inoltra.

Vantaggi:

- può applicare regole basate su URL, utenti o applicazioni;
- può richiedere autenticazione;
- può filtrare contenuti;
- può rilevare alcuni attacchi applicativi.

Svantaggi:

- è più lento;
- richiede configurazione;
- deve supportare i protocolli da controllare.

Un reverse proxy si mette davanti ai server interni. I client da Internet parlano con il reverse proxy, che poi smista le richieste verso i server reali.

Il reverse proxy:

- nasconde i server interni;
- può bilanciare il carico;
- può filtrare attacchi;
- è spesso collocato in DMZ.

Un bastion host è un server esposto o semi-esposto, progettato per essere particolarmente robusto e controllato. Di solito offre un servizio specifico verso l'esterno o funge da punto di accesso amministrativo, con configurazione minima, aggiornamenti frequenti e log attenti. In una progettazione sicura può essere collocato nella DMZ.

Next-Generation Firewall

Un NGFW, Next-Generation Firewall, combina più tecnologie:

- packet filtering;
- stateful inspection;
- deep packet inspection;
- IPS integrato;
- rilevamento malware;
- controllo applicazioni e utenti;
- analisi del traffico anche con tecniche moderne.

Rispetto a un proxy tradizionale, un NGFW è più scalabile e può analizzare molti tipi di traffico in tempo reale. In alcune configurazioni può fare anche TLS inspection, cioè ispezionare traffico cifrato dopo averlo terminato e ricifrato secondo policy aziendali.

DMZ, Demilitarized Zone

La DMZ è una zona di rete separata che ospita servizi accessibili da Internet senza esporre direttamente la LAN interna.

Nella DMZ si possono collocare:

- web server;
- mail server;
- DNS pubblico;
- FTP server;
- reverse proxy.

Serve perché alcuni servizi devono essere raggiungibili dall'esterno, ma se venissero compromessi l'attaccante non dovrebbe poter entrare direttamente nella rete interna.

Configurazioni possibili:

- DMZ con un solo firewall: usa una terza interfaccia del firewall; è semplice ma il firewall diventa un single point of failure;
- DMZ tra due firewall: un firewall esterno separa Internet dalla DMZ e uno interno separa DMZ e LAN; è più sicura;
- DMZ stratificata: più DMZ e più firewall in cascata, usati in contesti ad alta sicurezza come banche, sanità ed e-commerce.

Regole tipiche:

- Internet può raggiungere solo i servizi pubblici nella DMZ;
- la DMZ può comunicare con la LAN interna solo per servizi strettamente necessari;
- la LAN può amministrare la DMZ con protocolli sicuri;
- traffico non esplicitamente autorizzato deve essere bloccato.

Parole chiave

CIA triad, segretezza, integrità, disponibilità, Zero Trust, sniffing, packet sniffer, Wireshark, Disaster Recovery Plan, RTO, RPO, backup 3-2-1, fault tolerance, RAID, UPS, Business Continuity, minimo privilegio, audit log, malware, virus, worm, trojan, ransomware, spyware, rootkit, EDR, IDS, IPS, SGSI, ISO/IEC 27001, PDCA, GDPR, privacy by design, data breach, DPO, MFA, TOTP, OTP, passkey, FIDO2, S/MIME, PGP, OpenPGP, SPF, DKIM, DMARC, SSL, TLS, TLS 1.3, HTTPS, HSTS, forward secrecy, ECDHE, handshake, certificato X.509, CA, Record Layer, VPN, tunneling, IPsec, modalità tunnel, modalità trasporto, NAT-T, OpenVPN, WireGuard, site-to-site, end-to-site, end-to-end, intranet, extranet, NAS, RADIUS, AAA, firewall, packet filtering, default deny, stateful inspection, proxy, reverse proxy, NGFW, deep packet inspection, ACL, bastion host, DMZ.

Da integrare con le presentazioni

- Eventuali esercizi Packet Tracer su firewall, DMZ, VPN e policy di sicurezza.
-

Scheda 6

MODULO VI - Filtraggio del traffico di rete e ACL

Obiettivo del modulo

Capire come usare le Access Control List per filtrare il traffico e come NAT/PAT permettono la comunicazione tra reti private e Internet.

Argomenti da sviluppare

- ACL standard.
- Wildcard mask.
- ACL estese.
- NAT statico.
- NAT dinamico.
- NAT overload o PAT.

Schema sintetico iniziale

Le ACL sono liste di regole usate sui router per permettere o negare traffico in base a criteri specifici. Le ACL standard filtrano principalmente in base all'indirizzo IP sorgente, mentre le ACL estese possono considerare anche indirizzo di destinazione, protocollo e porte.

Le wildcard mask indicano quali bit dell'indirizzo devono essere controllati e quali possono variare. Sono quindi fondamentali per scrivere regole corrette nelle ACL Cisco.

Il NAT traduce indirizzi privati in indirizzi pubblici. Nel NAT statico la corrispondenza è fissa, nel NAT dinamico viene scelta da un pool di indirizzi pubblici, mentre il PAT permette a molti host interni di condividere un unico indirizzo pubblico distinguendo le connessioni tramite le porte.

Parole chiave

ACL, permit, deny, wildcard mask, ACL standard, ACL estesa, sorgente, destinazione, protocollo, porta, NAT statico, NAT dinamico, PAT, overload.

Da integrare con le presentazioni

- Sintassi delle ACL standard ed estese.
 - Regole di posizionamento delle ACL.
 - Esempi Packet Tracer con ACL e NAT/PAT.
 - Creazione di una DMZ con ACL e PAT.
-

Scheda 7

MODULO VII - Le reti wireless

Obiettivo del modulo

Studiare il funzionamento delle reti senza fili, gli standard IEEE 802.11, i meccanismi di accesso al mezzo, la sicurezza Wi-Fi e le principali architetture wireless.

Argomenti da sviluppare

- Standard IEEE 802.11 a, b, g, n.
- Basi delle diverse modulazioni.
- Protocolli di sicurezza WPA, WPA2, WPA3.
- Autenticazione 802.1X.
- Server RADIUS.
- Trasmissione wireless: CSMA/CA e RTS/CTS.
- Handoff e problemi tipici della trasmissione wireless.
- Struttura del frame 802.11.
- Architettura delle reti wireless.
- BSS ed ESS.
- BSS-ID e SSID.
- Ruolo dell'access point e distribution system.
- Trasmissione cellulare.
- Connessione satellitare.
- GPS.

Schema sintetico iniziale

Le reti wireless permettono la comunicazione senza cavi usando onde radio. Lo standard IEEE 802.11 definisce il funzionamento delle reti Wi-Fi e comprende diverse versioni, come 802.11a, 802.11b, 802.11g e 802.11n, che differiscono per frequenze, velocità e tecniche di modulazione.

Nel Wi-Fi non è possibile usare il CSMA/CD tipico delle reti Ethernet cablate, quindi si usa CSMA/CA, che cerca di evitare le collisioni prima della trasmissione. RTS/CTS può aiutare a ridurre problemi come il nodo nascosto.

La sicurezza si è evoluta da protocolli meno robusti a soluzioni più sicure come WPA2 e WPA3. L'autenticazione 802.1X con server RADIUS consente un controllo centralizzato degli accessi.

UNITA 1 - Classificazione delle reti wireless

Le reti wireless usano onde radio o segnali elettromagnetici per trasmettere dati senza cavi. Come le reti cablate, possono essere classificate in base all'estensione dell'area coperta.

Tipo	Estensione	Esempi
WPAN	Reti personali, pochi metri	Bluetooth, NFC, ZigBee, UWB
WLAN	Reti locali wireless	Wi-Fi, standard IEEE 802.11
WMAN	Reti metropolitane	FWA, vecchio WiMAX
WWAN	Reti geografiche	4G, 5G, connessioni satellitari

Le WPAN collegano dispositivi vicini, come cuffie, smartwatch, sensori o smartphone. Le WLAN sostituiscono o integrano le LAN cablate in case, scuole e aziende. Le WMAN e WWAN coprono aree più ampie, fino alla scala cittadina o globale.

WPAN: Bluetooth, NFC e altre tecnologie

Bluetooth è una tecnologia WPAN usata per comunicazioni a corto raggio. Opera nella banda a 2,4 GHz e usa tecniche come FHSS, Frequency Hopping Spread Spectrum, cioè salta rapidamente tra canali diversi per ridurre interferenze.

Esempi d'uso:

- cuffie e casse audio;
- smartwatch;
- tastiere e mouse wireless;
- dispositivi medici;
- sensori IoT.

NFC, Near Field Communication, è pensato per distanze molto brevi, dell'ordine di pochi centimetri. Lavora a 13,56 MHz ed è usato per pagamenti contactless, badge, tag e autenticazione di prossimità.

Modalità NFC:

- card emulation: lo smartphone si comporta come una carta;
- reader/writer: il dispositivo legge tag NFC;
- peer-to-peer: due dispositivi NFC attivi scambiano piccoli dati.

Altre tecnologie WPAN:

- ZigBee, basato su IEEE 802.15.4, usato per reti mesh a basso consumo;
- UWB, Ultra-Wideband, usato per localizzazione precisa in ambienti indoor;
- BAN, Body Area Network, per sensori medicali indossabili.

WLAN e standard IEEE 802.11

Le WLAN, Wireless Local Area Network, sono reti locali senza fili. Hanno una copertura indicativa da 30 metri in ambienti interni fino a circa 150 metri in campo aperto, a seconda di ostacoli, potenza, interferenze e frequenza.

Lo standard principale è IEEE 802.11, cioè il Wi-Fi.

Gli standard storici più importanti sono:

Standard	Banda	Caratteristiche
802.11a	5 GHz	Maggiore velocità rispetto ai primi standard, minore portata
802.11b	2,4 GHz	Buona portata, velocità più bassa
802.11g	2,4 GHz	Compatibile con 802.11b, velocità superiore
802.11n	2,4/5 GHz	Introduce MIMO, migliori prestazioni

Gli standard moderni sono:

Nome	Standard	Bande	Note
Wi-Fi 5	802.11ac	5 GHz	Ancora molto diffuso
Wi-Fi 6	802.11ax	2,4/5 GHz	OFDMA, migliore gestione di molti dispositivi
Wi-Fi 6E	802.11ax	2,4/5/6 GHz	Aggiunge banda 6 GHz, meno interferenze
Wi-Fi 7	802.11be	2,4/5/6 GHz	Multi-Link Operation, prestazioni molto elevate

Frequenze: 2,4 GHz, 5 GHz e 6 GHz

Le bande Wi-Fi hanno caratteristiche diverse:

- 2,4 GHz: maggiore copertura e migliore attraversamento degli ostacoli, ma velocità più bassa e più interferenze;
- 5 GHz: velocità più alta e meno interferenze, ma portata inferiore;
- 6 GHz: usata dagli standard più recenti, offre alta velocità e bassa interferenza, ma copertura minore.

In una progettazione WLAN bisogna scegliere frequenze e canali considerando copertura, numero di utenti, ostacoli, interferenze e applicazioni richieste.

WMAN, WWAN, reti cellulari e satellitari

Le WMAN coprono aree metropolitane. Storicamente si citava WiMAX, standard IEEE 802.16, ma oggi la soluzione più comune è FWA, Fixed Wireless Access, spesso basata su 4G/5G.

Configurazioni WMAN:

- point-to-point: collega due sedi, per esempio due edifici aziendali;
- point-to-multipoint: una stazione base serve più utenti o edifici.

Le WWAN coprono aree geografiche molto ampie. Comprendono:

- reti cellulari 4G/5G, e in prospettiva 6G;
- connessioni satellitari, per esempio sistemi LEO come Starlink.

Le reti cellulari moderne usano tecniche come OFDMA, che divide il canale radio in molte sottoportanti ortogonali. Il CDMA era usato in generazioni precedenti, come il 3G.

Il GPS non è una rete dati bidirezionale: è un sistema satellitare di posizionamento che permette ai ricevitori di calcolare la propria posizione usando segnali provenienti dai satelliti.

Sicurezza delle reti wireless

Le reti wireless sono più esposte di quelle cablate, perché il segnale radio si propaga nell'ambiente e può essere intercettato anche senza accesso fisico al cavo.

Rischi:

- intercettazione del traffico;
- access point non autorizzati;
- spoofing e attacchi ARP;
- password deboli;
- attacchi a dizionario;
- denial of service tramite frame di gestione.

Per proteggere una rete Wi-Fi servono:

- crittografia, per rendere il traffico non leggibile;
- autenticazione, per verificare chi può accedere;
- configurazioni aggiornate, evitando protocolli obsoleti.

Protocolli:

- WEP: obsoleto e insicuro;
- WPA con TKIP: oggi non raccomandato;
- WPA2: basato su AES/CCMP, ancora molto usato;
- WPA3: standard moderno, più sicuro.

WPA2 e WPA3

WPA2 usa AES e CCMP per garantire confidenzialità e integrità. Può funzionare in due modalità:

- Personal, o PSK: una password condivisa tra gli utenti;
- Enterprise: autenticazione 802.1X con server RADIUS.

Il limite di WPA2-PSK è che, se la password è debole, può essere attaccata tramite dizionario offline partendo dal 4-way handshake.

WPA3 migliora la sicurezza introducendo:

- SAE, Simultaneous Authentication of Equals, al posto del classico PSK;
- protezione migliore contro attacchi a dizionario offline;
- OWE, Opportunistic Wireless Encryption, per cifrare reti pubbliche aperte;
- chiavi più robuste in modalità Enterprise;
- Management Frame Protection 802.11w, per proteggere i frame di gestione.

WPA3 è richiesto negli standard Wi-Fi più recenti, come Wi-Fi 6/6E/7.

Autenticazione 802.1X con RADIUS

In ambito aziendale non è sufficiente una sola password condivisa. Si usa quindi IEEE 802.1X, che permette autenticazione centralizzata e per utente.

Componenti:

- supplicant: il client che vuole accedere alla rete;
- authenticator: access point o switch che controlla l'accesso;

- authentication server: server RADIUS che verifica le credenziali.

Funzionamento:

1. il client entra nel raggio dell'AP e richiede accesso;
2. l'AP chiede le credenziali;
3. il client invia la propria identità;
4. l'AP inoltra la richiesta al server RADIUS usando EAP;
5. il server verifica le credenziali;
6. se sono corrette, invia Accept e le chiavi di sessione;
7. l'AP apre la connessione protetta.

Questo sistema permette credenziali individuali, revoca degli utenti e controllo più preciso rispetto a una password unica condivisa.

UNITA 2 - Trasmissione e architettura delle reti wireless

Nelle reti cablate Ethernet tradizionali si usava CSMA/CD, Collision Detection: il nodo trasmette e, se rileva una collisione, interrompe e ritrasmette.

Nel Wi-Fi non è possibile rilevare le collisioni nello stesso modo, perché una stazione non può ascoltare perfettamente mentre trasmette e perché il mezzo radio è condiviso in modo più complesso. Per questo IEEE 802.11 usa CSMA/CA, Collision Avoidance.

CSMA/CA

CSMA/CA significa:

- Carrier Sense: la stazione ascolta il canale prima di trasmettere;
- Multiple Access: più stazioni condividono lo stesso mezzo radio;
- Collision Avoidance: si cerca di evitare la collisione prima che avvenga.

Funzionamento base:

1. la stazione ascolta il canale;
2. se il canale è occupato, aspetta;
3. quando il canale diventa libero, attende un intervallo DIFS;
4. sceglie un tempo casuale di backoff;
5. quando il backoff termina, trasmette;
6. il destinatario invia un ACK;
7. se l'ACK non arriva, si presume errore o collisione e si ritrasmette.

DCF, Distributed Coordination Function, è la modalità più comune: ogni stazione gestisce autonomamente l'accesso al mezzo seguendo CSMA/CA.

PCF, Point Coordination Function, è una modalità centralizzata in cui l'AP coordina le trasmissioni, ma è poco diffusa.

RTS/CTS

RTS/CTS è un meccanismo opzionale per ridurre le collisioni, soprattutto nel problema del nodo nascosto.

Passaggi:

1. la stazione invia RTS, Request To Send;
2. l'access point risponde con CTS, Clear To Send;
3. le altre stazioni ricevono il CTS e restano in attesa;
4. la stazione trasmette i dati;
5. il destinatario conferma con ACK.

RTS/CTS introduce overhead, ma può migliorare la comunicazione in reti con molte stazioni o con problemi di copertura.

Problemi tipici della trasmissione wireless

Le reti wireless devono affrontare problemi fisici assenti o meno evidenti nelle reti cablate.

Problema	Descrizione	Possibile soluzione
Attenuazione	Il segnale perde potenza con la distanza e con gli ostacoli	più AP, antenne migliori, progettazione copertura
Interferenze	Altri dispositivi disturbano il segnale	scelta canali, bande 5/6 GHz, pianificazione radio
Multipath	Il segnale rimbalza e arriva per percorsi diversi	OFDM, MIMO, progettazione corretta
Effetto Doppler	Movimento modifica la frequenza percepita	adattamento dinamico nelle reti mobili

Il problema del nodo nascosto si verifica quando due stazioni non si sentono tra loro, ma entrambe comunicano con lo stesso AP: possono trasmettere insieme e causare collisione presso l'AP. RTS/CTS aiuta a ridurre questo problema.

Il problema della stazione esposta si verifica quando una stazione evita di trasmettere perché sente un'altra trasmissione, anche se in realtà potrebbe comunicare senza interferire. Questo riduce inutilmente la capacità della rete.

Frame 802.11

Nelle reti Wi-Fi i dati e le informazioni di controllo viaggiano dentro frame 802.11. I frame principali sono:

- frame dati: trasportano il traffico degli utenti;
- frame di controllo: aiutano a gestire l'accesso al mezzo, per esempio RTS, CTS e ACK;
- frame di gestione: servono per scoprire reti, associarsi e mantenere la connessione, per esempio beacon, probe request/response, association request/response.

I beacon vengono inviati periodicamente dagli access point e contengono informazioni come SSID e BSSID. I frame di gestione sono importanti per il funzionamento della rete, ma possono essere bersaglio di attacchi; per questo WPA3 richiede la protezione dei frame di gestione tramite 802.11w.

Componenti di una rete wireless

Componenti principali:

- host wireless: smartphone, notebook, tablet, stampanti Wi-Fi, telecamere, dispositivi IoT;
- access point: collega i client wireless alla rete cablata;
- infrastruttura o distribution system: rete che collega AP, switch, router e Internet;

- wireless link: collegamento radio tra client e access point.

Una rete con AP collegati a una rete cablata viene detta rete con infrastruttura.

BSS, ESS, BSSID e SSID

Il BSS, Basic Service Set, e l'unità base di una rete Wi-Fi: un access point e tutti i client associati a esso.

L'area coperta dall'AP è detta BSA, Basic Service Area.

Il BSSID identifica il BSS ed è normalmente l'indirizzo MAC dell'access point.

L'SSID, Service Set Identifier, è il nome della rete Wi-Fi visibile agli utenti, per esempio `Scuola-WiFi`.

Differenza importante:

- BSSID: identifica una cella/AP specifico;
- SSID: identifica la rete logica.

Un ESS, Extended Service Set, è formato da più BSS collegati dallo stesso distribution system e con lo stesso SSID. Permette a un utente di spostarsi tra AP diversi mantenendo la connessione.

Roaming, handoff e scanning

Il roaming è il passaggio di una stazione da un AP a un altro.

Tipi:

- stazione statica: resta nello stesso BSS;
- transizione tra BSS dello stesso ESS: roaming trasparente, stesso SSID e di solito stesso indirizzo IP;
- transizione tra ESS diversi: cambio rete, nuova autenticazione e spesso nuovo indirizzo IP.

Nello stesso ESS il roaming è gestito a livello 2: la stazione invia una re-association request al nuovo AP e il distribution system aggiorna le tabelle di forwarding. Standard come 802.11r riducono la latenza del roaming, utile per VoIP e applicazioni real-time.

Per trovare gli AP disponibili, una stazione esegue scanning:

- scanning attivo: invia Probe Request e riceve Probe Response;
- scanning passivo: ascolta i beacon periodici trasmessi dagli AP.

I beacon contengono informazioni come SSID e BSSID.

Ruolo e modalità dell'access point

Un access point può lavorare in diverse modalità:

Modalità	Descrizione
Root mode	Modalità standard: AP collegato alla LAN cablata e usato dai client
Bridge mode	Collega segmenti di rete cablata tramite collegamento wireless
Repeater mode	Ritrasmette il segnale di un AP per estendere la copertura
Mesh mode	Più AP formano una rete magliata e si instradano tra loro

In repeater mode la banda disponibile può ridursi, perché l'AP riceve e ritrasmette sullo stesso canale. Le reti mesh moderne migliorano la copertura usando più nodi e, spesso, una banda dedicata per il collegamento tra AP.

Parole chiave

Wireless, WPAN, WLAN, WMAN, WWAN, Bluetooth, NFC, ZigBee, UWB, Wi-Fi, IEEE 802.11, 802.11a, 802.11b, 802.11g, 802.11n, Wi-Fi 5, Wi-Fi 6, Wi-Fi 6E, Wi-Fi 7, 2,4 GHz, 5 GHz, 6 GHz, OFDMA, OFDM, MIMO, FWA, WiMAX, rete cellulare, 4G, 5G, satellite, GPS, WPA2, WPA3, AES, CCMP, SAE, OWE, 802.1X, RADIUS, EAP, PSK, CSMA/CA, DCF, PCF, DIFS, SIFS, backoff, RTS/CTS, ACK, attenuazione, interferenza, multipath, nodo nascosto, stazione esposta, BSS, BSA, ESS, BSSID, SSID, access point, distribution system, roaming, handoff, scanning, beacon, root mode, bridge mode, repeater mode, mesh mode.

Da integrare con le presentazioni

- Eventuali esercizi o schemi Packet Tracer sulle reti wireless.
-

Scheda 8

MODULO DI LABORATORIO

Obiettivo del modulo

Raccogliere le esercitazioni pratiche svolte con Packet Tracer e con macchine virtuali, collegandole agli argomenti teorici del programma.

Attività da organizzare

- Simulazione di reti client-server.
- Applicazioni del livello applicativo.
- DNS.
- FTP.
- SMTP/POP3.
- DHCP.
- WWW.
- Crittografia con PGP/GPG in macchina virtuale.
- VLAN tagged e untagged.
- NAT/PAT.
- Firewall.
- ACL standard ed estese.
- Creazione di una DMZ con ACL e PAT.

Struttura consigliata per ogni esercitazione

Per ogni laboratorio si potrà usare sempre lo stesso schema:

1. obiettivo dell'esercizio;
2. topologia di rete;
3. indirizzamento IP;
4. configurazione dei dispositivi;
5. test di funzionamento;
6. problemi incontrati e soluzione;
7. collegamento con la teoria.

Da integrare con le presentazioni

- Screenshot o descrizioni delle topologie Packet Tracer.
 - Tabelle di indirizzamento.
 - Comandi principali usati sui dispositivi.
 - Test finali: ping, browser, posta, FTP, DNS lookup.
-

Scheda 9

MODULO PER SECONDA PROVA ESAMI DI STATO

Obiettivo del modulo

Preparare la parte progettuale della seconda prova, con attenzione al cablaggio strutturato, ai mezzi trasmissivi, agli apparati di rete e alla progettazione di infrastrutture coerenti con le richieste del testo.

Argomenti da sviluppare

- Cablaggio strutturato.
- Cablaggio orizzontale e verticale secondo lo standard ISO/IEC 11801.
- Mezzi trasmissivi: doppino, fibra ottica, onde radio.
- Armadi rack.
- Dispositivi di comunicazione in rete.
- Esercizi di cablaggio.
- Simulazioni di progettazione di reti.

Schema sintetico iniziale

Il cablaggio strutturato organizza l'infrastruttura fisica di rete in modo ordinato, scalabile e manutenibile. Il cablaggio orizzontale collega gli armadi di piano alle prese utente, mentre il cablaggio verticale collega tra loro i diversi piani o edifici, spesso usando fibra ottica per distanze maggiori e migliori prestazioni.

Nella progettazione di una rete bisogna considerare numero di utenti, servizi richiesti, separazione logica tramite VLAN, sicurezza, accesso a Internet, server interni, eventuale DMZ, indirizzamento IP e dispositivi necessari.

Parole chiave

Cablaggio strutturato, ISO/IEC 11801, cablaggio orizzontale, cablaggio verticale, doppino, fibra ottica, onde radio, rack, switch, router, firewall, access point, patch panel, progettazione di rete.

Da integrare con le presentazioni

- Schema tipo per rispondere a una traccia di seconda prova.
 - Tabelle per indirizzamento IP e subnetting.
 - Criteri per scegliere switch, router, firewall e access point.
 - Esempi di progetto con VLAN, NAT/PAT, ACL, DMZ e servizi interni.
-

Indice di integrazione futuro

Materiali da aggiungere modulo per modulo

- Presentazione Modulo I - Trasporto e UDP: integrata.
- Presentazione Modulo I - Trasferimento affidabile e TCP: integrata.
- Presentazione Modulo II - Livello applicazioni, WWW e FTP: integrata.
- Presentazione Modulo II - Email, DNS e Telnet/SSH: integrata.
- Presentazione Modulo II - Protocollo HTTP e cenni HTTPS: integrata.
- Presentazione Modulo II - DHCP: non necessaria su richiesta.
- Presentazione Modulo III - Virtual LAN: integrata.
- Presentazione Modulo III - VTP e Inter-VLAN Routing: integrata.
- Presentazione Modulo IV - Crittografia simmetrica, DES e AES: integrata.
- Presentazione Modulo IV - Crittografia asimmetrica, Diffie-Hellman, RSA e ibrida: integrata.
- Presentazione Modulo IV - Sistemi di autenticazione, firma, hash, certificati e PKI: integrata.
- Presentazione Modulo V - Sicurezza nei sistemi informativi: integrata.
- Presentazione Modulo V - Sicurezza con TLS: integrata.
- Presentazione Modulo V - VPN, IPsec, intranet, extranet e RADIUS: integrata.
- Presentazione Modulo V - Firewall, proxy, ACL e DMZ: integrata.
- Presentazione Modulo VI: non necessaria su richiesta.
- Presentazione Modulo VII - Reti wireless: integrata.
- Presentazione Modulo VII - Trasmissione e architettura wireless: integrata.
- Materiali di laboratorio: non necessari su richiesta.
- Materiali per seconda prova: non necessari su richiesta.

Possibili collegamenti per l'orale

- Sicurezza informatica e tutela dei dati.
- Crittografia, privacy e comunicazioni sicure.
- Reti aziendali, VLAN, DMZ e protezione dei servizi.
- Internet, protocolli applicativi e infrastrutture digitali.
- Wireless, mobilità e comunicazioni moderne.
- Progettazione di rete e organizzazione dei sistemi informativi.